



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie TR-03169

IT-sicherheitstechnische Anforderungen zur Durchführung von nicht-parlamentarischen Onlinewahlen und -Abstimmungen

Version 1.1



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
0.6	08.12.2022	BSI	Entwurf
0.7	31.03.2023	BSI	Erster veröffentlichter Entwurf
1.0	19.09.2023	BSI	Redaktionelle Änderungen
1.1	22.08.2025	BSI	Redaktionelle Änderungen Hinzufügen des Anhangs 2

Tabelle 1: Versionierung

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
E-Mail: online-wahlen@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2025

Inhaltsverzeichnis

1	Einleitung.....	5
1.1	Zielgruppe	5
1.2	Geltungsbereich	5
1.3	Zielsetzung	6
1.4	Formalia	6
2	Regulatorisches und gesetzliches Umfeld	7
2.1	Verschiedene Kontexte von Wahlen.....	7
2.2	Angreifermodelle	8
2.3	Schutzbedarf.....	9
2.4	Risiken.....	9
2.5	Einordnung des Schutzprofils BSI-CC-PP-0121	11
3	Onlinewahl	14
3.1	Allgemeiner Ablauf einer Wahl.....	14
3.2	Vorbereitungsphase	15
3.2.1	Aspekte der Vorbereitungsphase	15
3.2.2	Anforderungen an die Vorbereitungsphase.....	18
3.3	Durchführungsphase	24
3.3.1	Aspekte der Durchführungsphase	24
3.3.2	Anforderungen an die Durchführungsphase	25
3.4	Auswertungsphase.....	26
3.4.1	Aspekte der Auswertungsphase	26
3.4.2	Anforderungen an die Auswertungsphase	27
3.5	Nachbereitungsphase	28
3.5.1	Aspekte der Nachbereitungsphase.....	28
3.5.2	Anforderungen an die Nachbereitungsphase	28
4	Schlusswort	29
5	Anhang 1: BSI IT-Grundschutz bei Onlinewahlen	30
5.1	Umsetzungshinweise zum BSI IT-Grundschutz	30
5.1.1	Durchführung von BSI IT-Grundschutz.....	31
5.1.2	Notfallmanagement.....	40
6	Anhang 2: Durchführung einer hybriden Wahl.....	45
6.1	Einführung in hybride Wahlen	45
6.2	Wahlgrundsätze	46
6.3	Herausforderungen von hybriden Wahlen.....	47
6.4	Durchführung von hybriden Wahlen	48
6.4.1	Möglicher Ablauf einer hybriden Wahl	48

6.4.2	Technische und organisatorische Besonderheiten.....	49
6.5	Fazit.....	50
7	Glossar	51
8	Literaturverzeichnis.....	55

1 Einleitung

Die vorliegende Technische Richtlinie befasst sich mit der Umsetzung von nicht-politischen Onlinewahlen und -Abstimmungen (siehe dazu auch Kapitel 1.2). Bei einer Onlinewahl erfolgt die Stimmabgabe der Wahlberechtigten mittels elektronischer Eingabegeräte (z.B. Smartphone oder PC) über ein Rechnernetzwerk (z.B. Internet oder Intranet). Die Stimmen werden an ein Onlinewahlsystem geleitet und dort verarbeitet.

Grundsätzlich finden bei vielen Wahlen die fünf Wahlgrundsätze allgemein, unmittelbar, frei, gleich und geheim Anwendung. Neben den fünf Wahlgrundsätzen wird häufig noch von der Öffentlichkeit der Wahl gesprochen. Hierbei geht es darum, dass für die Wählenden die wesentlichen Schritte der Wahlhandlung und der Ergebnisermittlung zuverlässig und ohne besondere Sachkenntnis überprüfbar sein müssen (1).

Die vorliegende Technische Richtlinie hat zum Ziel für Onlinewahlen und -Abstimmungen gleichermaßen zu gelten. Sie sagt jedoch nichts über die rechtliche Zulässigkeit der Durchführung von elektronischen Wahlen aus.

Die betroffenen Wahlgrundsätze können sich je nach Umstand und rechtlicher Grundlage unterscheiden. Durch Unterschiede in der Handhabung der Wahlgrundsätze zwischen Onlinewahlen und Onlineabstimmungen, kann es zu unterschiedlichen Anforderungen kommen. Generell gilt, dass die Umsetzung höherwertiger Anforderungen und Maßnahmen für Onlinewahlen auch die Absicherung von Onlineabstimmungen ermöglicht.

Das Onlinewahlsystem ist eine IT-Umgebung, die für die Durchführung einer Onlinewahl notwendig ist. Die detaillierten IT-Sicherheitsanforderungen an ein Onlinewahlprodukt werden im Schutzprofil CC-PP-0121 (2) genannt.

Für die Planung und Umsetzung der Onlinewahl und die Durchführung einzelner Maßnahmen, kann technische Expertise erforderlich sein. Der Wahlvorstand wird daher angehalten, vor der Umsetzung einer Onlinewahl bei Bedarf technischen Sachverstand hinzuzuziehen. Für die Durchführung einer Onlinewahl empfehlen wir die Umsetzung von BSI IT-Grundschutz, zu der auch die Erstellung eines IT-Sicherheitskonzeptes gehört.

1.1 Zielgruppe

Die TR richtet sich in erster Linie an den jeweiligen Wahlvorstand, bei einer durchzuführenden Onlinewahl. Das zugehörige Schutzprofil CC-PP-0121 (2) adressiert Hersteller von Onlinewahlprodukten und enthält Anforderungen an das eingesetzte Onlinewahlprodukt.

1.2 Geltungsbereich

Die vorliegende Technische Richtlinie findet für geheime nicht-politische Onlinewahlen und -Abstimmungen Anwendung.

Dazu gehört explizit die Wahl zur Gleichstellungsbeauftragten gemäß § 19 Gleichstellungsbeauftragtenwahlverordnung (3). Weiterhin kann diese Technische Richtlinie auch für andere nicht-politische Onlinewahlen, wie Vereinswahlen oder nicht-politische Abstimmungen Anwendung finden.

Nicht betroffen sind politische Wahlen, wie Kommunal-, Landtags- oder Bundestagswahlen, politische Abstimmungen.

Diese TR beinhaltet auch Umsetzungshinweise und -vorlagen. Diese finden Sie hier:

https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03169/gesammelte-Publikation_TR-03169.html.

Die Muster sind reine Beispiele. Bei der Nutzung der Vorlagen müssen diese auf Ihre Bedürfnisse und Rahmenbedingungen angepasst werden. Datenschutzrechtliche Anforderungen sind nicht Bestandteil der vorliegenden TR. Bei der Verarbeitung personenbezogener Daten sind die einschlägigen Bestimmungen zum Datenschutz EU-DSGVO, BDSG (4) einzuhalten.

1.3 Zielsetzung

Um zu gewährleisten, dass sowohl die betroffenen Wahlgrundsätze als auch die Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit ausreichend betrachtet und berücksichtigt werden, werden im Folgenden entsprechende Anforderungen an die Umsetzung einer Wahl formuliert, die diese Grundsätze und Ziele schützen.

1.4 Formalia

In der vorliegenden Technischen Richtlinie werden Anforderungen als Ausdruck normativer Festlegungen durch die in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS/MÜSSEN, DARF NICHT/DÜRFEN NICHT, DARF KEINE/DÜRFEN KEINE, SOLLTE/SOLLTEN, KANN/KÖNNEN entsprechend gekennzeichnet.

MUSS	Der Wahlvorstand muss eine bestimmte Anforderung zwingend umsetzen.
DARF NICHT/DARF KEINE	Der Wahlvorstand muss dafür sorgen, dass eine bestimmte Eigenschaft unter keinen Umständen vorhanden ist.
SOLLTE	Der Wahlvorstand muss eine bestimmte Anforderung umsetzen, außer es wird dargelegt, dass durch ein Nicht-Umsetzen kein Risiko für den sicheren Betrieb besteht, bzw. eine Umsetzung, aufgrund von technischen Einschränkungen, derzeit nicht möglich ist.
KANN	Eine Umsetzung kann eine bestimmte Anforderung erfüllen, wobei ein Umsetzen dieser Anforderung anzuzeigen ist.

Die im Kapitel 3 beschriebenen Anforderungen werden nach Basisanforderungen (B) und Anforderungen für hohen Schutzbedarf (H) der Onlinewahl unterschieden und sind entsprechend Ihres Anforderungskürzels gekennzeichnet.

Diese Technische Richtlinie repräsentiert den Stand der Technik und wird fortlaufend aktualisiert.

2 Regulatorisches und gesetzliches Umfeld

Für alle Wahlen ist zu prüfen, welche gesetzlichen Anforderungen für die Durchführung einer Onlinewahl zum Einsatz kommen (z.B. durch eine Wahlverordnung). Daneben muss man sich über den Kontext und mögliche Einflüsse auf die Wahl Gedanken machen, die im Folgenden erläutert werden.

Wahl zur Gleichstellungsbeauftragten

Handelt es sich bei der durchzuführenden Onlinewahl um die Wahl zur Gleichstellungsbeauftragten in den Dienststellen des Bundes gelten die maßgeblichen regulatorischen Anforderungen:

- BSI IT-Grundschutz, 2023 (5)
- Art 38 GG (6) i.V.m. Art. 20 Abs. 1 und 2 GG
- BGleG - Gesetz für die Gleichstellung von Frauen und Männern in der Bundesverwaltung und in den Gerichten des Bundes (Bundesgleichstellungsgesetz – BGleG (7))
- Gleichstellungsbeauftragtenwahlverordnung vom 17. Dezember 2015 (BGBl. I S. 2274), die durch Artikel 3 des Gesetzes vom 7. August 2021 (BGBl. I S. 3311) zuletzt geändert worden ist. Für die Onlinewahl ist insbesondere § 19 GleichWV (8) maßgeblich.

Diese regulatorischen Anforderungen sind exemplarisch für eine Onlinewahl einer Gleichstellungsbeauftragten. Es gelten die regulatorischen Anforderungen gemäß der eigenen Wahlverordnung, sofern es diese gibt. Die hier aufgeführten regulatorischen Anforderungen können gegebenenfalls davon abweichen.

2.1 Verschiedene Kontexte von Wahlen

Es existieren unterschiedliche Abstimmungen und Wahlen. Beispielhaft seien genannt:

- Vereinswahlen
- Hauptversammlungen und General- bzw. Vertreterversammlungen
- Gremienwahlen z.B. an Universitäten (Senat, Studierendenparlament, etc.)
- Sozialwahl
- Wahl von Vertretungen (Personal- oder Betriebsrat, Gleichstellungsbeauftragte, Schwerbehindertenvertretung, Jugend- und Auszubildendenvertretung, etc.)
- Politische Wahlen (Kommunalwahl, Landtagswahl, Bundestagswahl, Europawahl)

Durch unterschiedliche Abstimmungen und Wahlen ergeben sich unterschiedliche Wahlausrichter bzw. Wahlverantwortliche:

- Vereine
- Institutionen und öffentliche Einrichtungen (z.B. Universitäten, Behörden, Kirchen)
- Unternehmen
- Kommune, Land, Bund

Ebenfalls kann sich der Kreis der Wählenden unterscheiden:

In der Regel werden diese Wahlen mit den jeweiligen

- Mitgliedern,
- Mitarbeitenden,
- Anteilseignern oder
- Versicherten

durchgeführt.

Zudem kann eine Wahl auch hybrid stattfinden. Dies bedeutet, dass Wählende neben der Möglichkeit, ihre Stimme online abzugeben, ebenfalls die Möglichkeit haben, per Brief und/oder in Präsenz zu wählen. Anhang 2 beschreibt dazu Herausforderungen, die zusätzlich adressiert werden müssen.

Abgrenzung

Im Fokus dieser Technischen Richtlinie liegen **geheime, nichtpolitische Wahlen und Abstimmungen** (siehe dazu Kapitel 1.2). Da die Anforderungen und Vorgehensweisen bei verschiedenen Abstimmungen und Wahlen stark voneinander abweichen können und hier auch für geheime Wahlen und Abstimmungen unterschiedliche Bedürfnisse zur Geltung kommen, wird sich die vorliegende TR im Folgenden auf Anforderungen und Hilfestellungen für die Umsetzung von geheimen Abstimmungen und Wahlen unter Betrachtung unterschiedlicher Schutzbedarfe beschränken. Nicht betrachtet werden in dieser Technischen Richtlinie **Öffentliche Abstimmungen und Live-Votings**.

2.2 Angreifermodelle

Angriffe auf Onlinewahlen können unterschiedlich ausfallen. Dies hängt auch von den Angreifern und deren Ursprung, Motivation und möglichem Vorwissen ab:

- **Externe Angreifer**

Ein Externer Angreifer versucht ein System aus dem Internet anzugreifen. Dabei versucht er mögliche Sicherheitslücken auszunutzen, um beliebige Daten an die exponierten Systeme zu schicken, Zugriff auf deren Daten zu erhalten, deren Daten zu manipulieren oder die Verfügbarkeit des Systems zu stören. Durch Angriffe wie Social-Engineering kann es einem externen Angreifer zudem möglich sein, Informationen über interne Systeme zu erlangen.

- **Interne Angreifer**

Interne Angreifer haben dieselben Möglichkeiten wie externe Angreifer. Darüber hinaus haben Sie Zugriff auf das interne Netzwerk eines Betreibers und ggf. auch auf besondere Kenntnisse oder Zugänge zu internen Systemen. Durch andere Einfallstore (z.B. infizierte Geräte), kann sich ein externer Angreifer ggf. Zugriff auf ein internes System verschaffen und damit unter Umständen auch auf die Möglichkeiten eines internen Angreifers. Unter interne Angreifer fallen auch böswillige Wahlberechtigte.

Zusätzlich zu der Aufteilung in externe und interne Angreifer können diese auch nach ihren unterschiedlichen Zielen und ihrem unterschiedlichen Vorwissen kategorisiert werden.

- **Technikenthusiast**

Ein Technikenthusiast ist ein weniger stark motivierter Angreifer mit begrenzter technischer Expertise auf dem Gebiet des Hackings und geringen finanziellen Mitteln. Darunter können auch sogenannte „Script Kiddies“ fallen. Diese durchforsten das Internet nach den benötigten Tools, Skripten und Anleitungen, um sich ein Grundwissen anzueignen, mit dem sie agieren können.

- **Hacker**

Dabei handelt es sich um motivierte Angreifer mit technischer Expertise auf dem Gebiet des Hackings, aber begrenzten Ressourcen, da für diesen Angreifer in der Regel die Kosten eines Angriffs im Verhältnis zu dessen Nutzen für ihn stehen müssen. Sie agieren häufiger mit einem konkreten Ziel/Motiv (z.B. Erpressung; im Kontext von Wahlen; ebenfalls denkbar wäre eine Manipulation der Wahlergebnisse oder eine Offenlegung der abgegebenen Stimmen). Im Gegensatz zum Technikenthusiasten ist dieser Angreifer auch in der Lage Skripte und Exploits selbst zu schreiben oder vorhandene anzupassen.

- **Staatlicher oder anderweitig unterstützter Akteur**

Diese hochmotivierten Angreifer können sowohl auf exzellente Fachkenntnisse als auch auf umfangreiche finanzielle und technische Ressourcen zurückgreifen. Beispiele für diese Angreifer wären Geheimdienstmitarbeitende oder Angreifer im Auftrag eines „motivierten“ großen Konzerns. Für diese Art von Angreifer muss kein besonderes Kosten/Nutzen-Verhältnis gelten.

2.3 Schutzbedarf

Aus den vorangegangenen Überlegungen ergibt sich eine heterogene Mischung von Einflüssen. Akteure mit unterschiedlicher Motivation und Fähigkeit führen dazu, dass einheitliche Maßnahmen zur Absicherung aller Wahlen nicht ausreichend sind. Mit der Größe der Schadensauswirkungen, die beim Angriff auf eine Wahl eintreffen können, steigt die Motivation für mögliche Angreifer. Dementsprechend kann davon ausgegangen werden, dass bei Wahlen mit besonders hoher Schadensauswirkung auch Angreifer mit größerer Motivation und entsprechend größerer fachlicher Expertise und mehr Ressourcen aktiv werden. Hieraus ergibt sich ein Zusammenhang zwischen Wahlen mit großer Schadensauswirkung, sprich hohem Schutzbedarf und den möglichen Angreifern für Wahlen aus dem Angreifermodell (siehe 2.2). Es ist erforderlich dies bei der Bestimmung des Schutzbedarfes zur berücksichtigen, um die Wahl entsprechend abzusichern.

Im Rahmen der Umsetzung des IT-Grundschutzes kann hier gezielt auf die Besonderheiten der jeweiligen Wahl eingegangen werden. Der Schutzbedarf nach IT-Grundschutz unterteilt sich in die Schutzbedarfe normal, hoch und sehr hoch, entsprechend der Schwere der Schadensauswirkungen, die im Rahmen der Schutzbedarfsfeststellung für die Zielobjekte ermittelt wurde. Im Anhang an diese Technische Richtlinie gibt es Hilfestellungen, Vorlagen und Beispiele zur Umsetzung von IT-Grundschutz.

Sollte das Ergebnis sein, dass die Durchführung der Onlinewahl einen sehr hohen Schutzbedarf hat, sollte in Erwägung gezogen werden, diese Wahl nicht online durchzuführen. Dies gilt insbesondere dann, wenn als mögliche Angreifer staatlich oder anderweitig unterstützte Akteure (zum Beispiel Geheimdienste, aber auch Angreifer im Auftrag eines „motivierten“ großen Konzerns) identifiziert wurden. Kann auf die Onlinewahl nicht verzichtet werden, sollte sich an den Anforderungen für den hohen Schutzbedarf orientiert und zusätzliche Maßnahmen zur Absicherung der Wahl ergriffen werden, auf die hier nicht näher eingegangen werden kann.

Zusätzlich zur Schutzbedarfsfeststellung spielt es eine Rolle, ob es sich bei Ihnen als Wahlverantwortliche um eine Behörde handelt und/oder ob Sie gemäß der entsprechenden Verordnung verpflichtet sind, die Anforderungen aus dieser Technischen Richtlinie umzusetzen.

Handelt es sich bei Ihnen um ein Unternehmen, einen Verein etc. und sind Sie nicht (gesetzlich) verpflichtet, die Anforderungen aus der vorliegenden Technischen Richtlinie umzusetzen, sind die vorliegenden Anforderungen und Hilfestellungen als Empfehlungen zu verstehen.

2.4 Risiken

Nach IT-Grundschutz wird eine Risikoanalyse immer dann vorgenommen, wenn:

- es Zielobjekte mit einem „hohen“ oder „sehr hohen“ Schutzbedarf gibt,
- Zielobjekte nicht hinreichend durch die Bausteine aus dem IT-Grundschutz abgebildet werden können oder
- Zielobjekte in Einsatzszenarien betrieben werden, die der IT-Grundschutz nicht abdeckt

Da Onlinewahlen ein spezielles Einsatzszenario sind, für das kein eigener Baustein im IT-Grundschutz existiert, der es hinreichend beschreibt, empfehlen wir in jeden Fall eine Risikoanalyse durchzuführen.

Dabei ist es wichtig, die spezifischen Risiken für eine Onlinewahl zu betrachten, einzuschätzen und entsprechende Maßnahmen zu ergreifen. Da Onlinewahlen unter verschiedenen Bedingungen, in andersartigen Kontexten und mit unterschiedlichen Zielsetzungen durchgeführt werden können, muss die Risikoanalyse genauso wie der geeignete Umgang mit den Risiken im Kontext der jeweiligen Onlinewahl

getroffen werden. Im Folgenden stellen wir deswegen eine Auflistung möglicher Risiken einer Onlinewahl zur Verfügung, mit der sich Wahlverantwortliche im Rahmen der Durchführung Ihrer Onlinewahl auseinandersetzen sollten:

	Risiken einer Onlinewahl
1	Angriffe auf notwendige Daten des Wahlverfahrens
1.1	Unberechtigtes Auslesen von Wählendenverzeichnissen, Wahllisten, Berechtigungen
1.2	Manipulation von Wählendenverzeichnissen, Wahllisten, Berechtigungen
1.3	Manipulation des Wahlzeitraums (Stimmabgabe nur im Wahlzeitraum möglich)
2	Angriffe auf das Onlinewahlssystem
2.1	Manipulation in der Entwicklung, Einrichtung und dem Betrieb des Onlinewahlsystems • Softwareentwicklung (Backdoors) • Manipulation von User Interfaces (Website Defacement) • Schadcode (Cross-Site-Skripting, Cross-Site-Request-Forgery, SQL Injection)
2.2	Unberechtigte Stimmabgabe, z.B. durch Man-in-the-Middle Attacke, Malware oder mangelnde oder fehlende Authentifizierung der Wählenden
2.3	Manipulation von (berechtigten) Stimmabgaben (Schnittstellen, Versand/Kommunikation, manipulierte Formulare, Änderung/Löschung/Hinzufügung gespeicherter Stimmen/Wählen im Namen Dritter) • Clash-Attacken • Ballot Stuffing (es gibt mehr abgegebene Stimmen als Wahlberechtigte, die ihre Stimme abgegeben haben)) • Manipulierte oder fehlerhafte Endgeräte • Fehlerhafter Server
2.4	Manipulation von Ergebnissen/Ergebnislisten (Extrahieren, Versand)
2.5	Einbruch in das Wahlsystem • Unberechtigter Zugriff auf das Onlinewahlssystem z. B. durch eine schwache Authentifizierung • Interne Angreifer
2.6	Angriff auf die Verfügbarkeit des Onlinewahlsystems • DDoS Attacken • Interne Angreifer
2.7	Angriff auf die Vertraulichkeit der Onlinestimme • Italienische Angriffe • Seitenkanalangriffe • Mangelhafte oder fehlende Verschlüsselung • Vote copying • Manipulierte Endgeräte
2.8	Beeinflussung von verantwortlichen Personen • Manipulation von Schlüsselpersonen (Funktionsposten) durch Social Engineering • Erpressung oder Bestechung von Admins, sodass diese zu Innentätern werden
2.9	Beeinflussung der Wahlberechtigten • Social Engineering, Erpressung zur Abgabe eines bestimmten Votums
2.10	Angriff auf die Wahlberechtigten • Phishing

Tabelle 2: Risiken

Auf der Webseite des BSI¹ gibt es Hilfestellungen, Vorlagen und Beispiele zur Umsetzung von IT-Grundschutz, unter anderem auch zur Durchführung einer Risikoanalyse für Onlinewahlen.

2.5 Einordnung des Schutzprofils BSI-CC-PP-0121

Bei der Auswahl einer Anwendung zur Einrichtung, Durchführung und Auswertung einer Onlinewahl kann auf ein nach Common Criteria (CC) zertifiziertes Produkt zurückgegriffen werden. Hierbei muss allerdings beachtet werden, dass die Zertifizierung konkrete Anforderungen an ein Produkt stellt, die ggf. nur die Bedürfnisse einiger bestimmter Wahlen widerspiegeln.

Das Schutzprofil (engl. Protection Profile; PP) BSI-CC-PP-0121 (2) betrachtet Onlinewahlen mit einem hohen Schutzbedarf gemäß BSI IT-Grundschutz. In diesem Kontext definiert es Sicherheitsanforderungen, die ein Onlinewahl-Produkt erfüllen muss, damit es nach diesem PP zertifiziert werden kann. Die Erfüllung der Sicherheitsanforderungen wird in einer Evaluierung überprüft, sodass das entsprechende Produkt nach dem Common-Criteria-Standard zertifiziert werden kann.

Für die Abwägung der Wahlgrundsätze geheim, frei und öffentlich wird im Rahmen des PP von einer Einschätzung ausgegangen, bei der alle drei betroffenen Wahlgrundsätze möglichst gleichmäßig gewichtet werden. Es werden Funktionalitäten und Anforderungen vorgesehen, die beispielsweise zur Erpressungsresistenz beitragen sollen, gleichermaßen werden Maßnahmen für die Umsetzung von Ende-zu-Ende-Verifizierbarkeit gefordert, die die Transparenz und damit den Öffentlichkeitsgrundsatz in einer Wahl adressieren.

Das Schutzprofil stellt Anforderungen an die Umsetzung kryptographischer Wahlverfahren durch ein Onlinewahl-Produkt. Dazu werden im Schutzprofil konkrete Anforderungen für die Umsetzung von Onlinewahlverfahren unter Nutzung von Mix-Nets oder homomorpher Verschlüsselung zum Schutz der Onlinestimmen formuliert. Dies adressiert insbesondere die Wahlgrundsätze geheim und frei, sowie das Schutzziel der Vertraulichkeit.

Die Sicherheitsanforderungen des Schutzprofils werden anhand sogenannter SFRs (Security Functional Requirements) umgesetzt und lassen sich in folgende Themen gliedern:

- **Zugriffskontrolle:**
Das Schutzprofil verlangt, dass Ressourcen und Interaktionsmöglichkeiten mit dem zu zertifizierenden Produkt durch eine Zugriffskontrolle geschützt sein müssen. In Abhängigkeit von Wahlphasen, Nutzerrollen und dem internen Zustand lässt das Produkt den Zugriff auf Ressourcen und Funktionen zu oder verwehrt ihn.
- **Datenimport und -export:**
Das Produkt muss vor Wahlbeginn einen Import von wahlbezogenen Konfigurationsdaten ermöglichen. Zudem müssen nach der Stimmauszählung sämtliche wahlrelevanten Daten kryptografisch gesichert exportierbar sein, um eine eigenständige Veröffentlichung der Daten außerhalb des Produkts zu ermöglichen. Dies dient auch der Möglichkeit einer unabhängigen Verifizierbarkeit der Wahl.
- **Sichere Kommunikationskanäle:**
Sämtliche Kommunikationskanäle des Produkts müssen nach den Vorgaben der TR-02102-2 (9) mittels TLS abgesichert sein.
- **Gesicherte Verarbeitung und Verifizierung von wahlbezogenen Daten:**
Das Schutzprofil verlangt, dass alle wahlbezogenen Daten (inklusive der abgegebenen Stimmen) auf eine im Schutzprofil definierte Art und Weise verarbeitet werden, sodass es den Wählenden ermöglicht wird, im Sinne einer Ende-zu-Ende-Verifizierbarkeit die Berücksichtigung ihrer abgegebenen Stimme zu verifizieren. Das Schutzprofil macht keine spezifischen Vorgaben dazu, wie

¹ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

die Verifizierbarkeit umgesetzt werden muss, da sich zum aktuellen Zeitpunkt noch keine klar zu präferierende Variante herauskristallisiert hat.

- **Stimmauszählung:**
Das Produkt muss die Stimmauszählung gemäß einem importierbaren Wahlregelsatz ermöglichen. Zugleich verlangt das Schutzprofil, dass die wahlbezogenen Daten integritätsgeschützt verarbeitet und gespeichert werden.
- **Log-Daten-Generierung:**
Sämtliche wahlbezogenen Vorgänge müssen vom Produkt auf nachvollziehbare und integritätsgeschützte Weise protokolliert werden, sodass administratives Personal jederzeit über den internen Zustand des Produkts informiert ist. Dies umfasst auch die Erkennung von Fehlerzuständen.
- **Nutzeridentifikation und -authentisierung:**
Das Schutzprofil verlangt, dass ein zu zertifizierendes Produkt administratives Personal, Wahlvorstände und Wählende identifizieren und authentisieren muss, bevor diese in Interaktion mit dem Wahlprodukt treten. Die Wahl der Authentifizierungsmethode lässt das Schutzprofil offen. Für die Wahl der Identifizierungs- und Authentifizierungsmechanismen sollten die Vorgaben der Technischen Richtlinie TR03107-1 „Elektronische Identitäten und Vertrauensdienste im E-Government“ (10) beachtet werden. Es wird empfohlen das gewählte Vertrauensniveau an dem Schutzbedarf der Wahl auszurichten. Dabei werden die Vertrauensniveaus in der TR-03107-1 wie folgt zugeordnet:
 - normal: Die Schadensauswirkungen bei einer Kompromittierung sind begrenzt und überschaubar. Dieses Vertrauensniveau entspricht in etwa dem Sicherheitsniveau normal gemäß IT-Grundschutz [BSI 200-2]. (11)
 - substantiell: Die Schadensauswirkungen bei einer Kompromittierung sind substantiell. Dieses Vertrauensniveau liegt zwischen den Sicherheitsniveaus normal und hoch gemäß IT-Grundschutz [BSI 200-2] (12).
 - hoch: Die Schadensauswirkungen bei einer Kompromittierung können beträchtlich sein. Dieses Vertrauensniveau entspricht in etwa dem Sicherheitsniveau hoch gemäß IT-Grundschutz [BSI 200-2] (12).

Die Annahmen des Schutzprofils BSI-CC-PP-0121

Das Schutzprofil beinhaltet Annahmen, die erfüllt sein müssen, damit das Onlinewahlprodukt eine sichere Onlinewahl durchführen kann (Siehe Kapitel 3.4 Assumptions im BSI-CC-PP-0121 (2)).

- **Beobachtung**
Der Wählende kann seine Stimme unbeobachtet abgeben. Der Wahlveranstalter ist dafür verantwortlich, dem Wählenden angemessene Anweisungen für die unbeobachtete Stimmabgabe zu geben.
- **A.AuthData**
Die Nutzer des Onlinewahlproduktes haben alle für die Durchführung der Wahl erforderlichen Daten, insbesondere die Identifikationsdaten und die Authentifizierungsdaten, erhalten. Die Nutzer geben sie nicht an andere Personen weiter.
- **A.TerminalDevice**
Für die Sicherung des Endgerätes ist der Wählende verantwortlich. Es wird davon ausgegangen, dass der Abstimmungsvorgang durch das Endgerät nicht beobachtet oder beeinflusst wird. Dazu gehört, dass der Wählende sein Endgerät nicht vorsätzlich zu solchen Zwecken manipuliert. Das Endgerät ist in der Lage, den Stimmzettel korrekt anzuzeigen, die Eingaben des Wählenden korrekt und verschlüsselt an das Onlinewahlprodukt zu übermitteln und Daten zu löschen, die nach der Wahlaktion Rückschlüsse auf die abgegebene Stimme zulassen. Mithilfe der verwendeten Endgeräte können Nutzer die Echtheit des Onlinewahlproduktes überprüfen. Jeder Wahlberechtigte verfügt über ein Endgerät, das die oben genannten Eigenschaften erfüllt.

Hinweis 1: Aufgrund des Wahlprinzips kann es erforderlich sein, dass der Stimmzettel barrierefrei präsentiert wird. A.TerminalDevice geht davon aus, dass das Endgerät in solchen Fällen in der Lage ist, den Stimmzettel barrierefrei anzuzeigen.

- Ein Netzwerk
Der Schutz der Server, auf denen das Onlinewahlprodukt läuft, wird durch die Implementierung eines Sicherheitskonzepts für die Netzwerkverbindung gewährleistet. Darüber hinaus ist eine ausreichende Dienstqualität und Verfügbarkeit des Netzes gewährleistet.
- Ein Server
Die Server, auf denen das Onlinewahlprodukt läuft, sind frei von schädlicher Software, die die Sicherheitsfunktionen des Onlinewahlproduktes beeinträchtigen könnte. Die gesamte Software auf den Servern ist vertrauenswürdig und wurde ordnungsgemäß installiert und aktualisiert. Unberechtigte Zugriffe auf Funktionen, Prozesse und Daten werden durch die Sicherheitsmechanismen der Server verhindert. Darüber hinaus sind die Server vor unbefugtem physischem Zugriff und physischer Manipulation geschützt.
- A.AuthServer
Abhängig von der Konfiguration des Endgeräts überprüft der Benutzer oder das Endgerät im Namen des Benutzers, ob das Endgerät mit dem richtigen Onlinewahlprodukt kommuniziert, bevor er mit dem Onlinewahlprodukt interagiert.

Sollte keine nach dem Schutzprofil BSI-CC-PP-0121 (2) zertifizierte Anwendung zur Durchführung einer Wahl genutzt werden, aber eine Anwendung eingesetzt werden, die für die Umsetzung eines kryptographischen Wahlverfahrens Mix-Nets oder homomorphe Verschlüsselung nutzt, dann können die entsprechenden Anforderungen der SFRs aus Kapitel 6.1 des Schutzprofils übernommen werden. Diese sollten dann dem Anbieter vorgelegt und von diesem die Einhaltung der SFRs bestätigt werden. Da dies auf den eigenen Aussagen des Anbieters beruht, bietet dies jedoch nicht so viel Sicherheit wie der Einsatz eines zertifizierten Produktes.

3 Onlinewahl

Die im Folgenden beschriebenen Anforderungen werden nach Basisanforderungen (B) und Anforderungen für hohen Schutzbedarf (H) unterschieden und sind entsprechend durch Ihr Anforderungskürzel gekennzeichnet. Für die Einordnung des eigenen Bedarfs siehe Kapitel 2.3 „Schutzbedarf“.

3.1 Allgemeiner Ablauf einer Wahl

Eine Onlinewahl bedarf einer gründlichen Vorbereitung, Durchführung, Auswertung sowie Aufbereitung und abgesicherter Archivierung im Anschluss der Wahl, um die Überprüfbarkeit der Integrität sicherzustellen. Grundsätzlich gliedert sich eine Onlinewahl in folgende vier Phasen:

Vorbereitungsphase,

Durchführungsphase,

Auswertungsphase,

Nachbereitungsphase.

Zur Wahl berechnigte Wählende können in einem Onlinewählendenverzeichnis (OWV) mit einem Wahlkennzeichen (WKZ) gelistet werden. Ein solches WKZ sollte einmalig, eindeutig, alphanumerisch und zufällig generiert werden. Sie gelten als Pseudonyme für die Wahlberechtigten, so dass eine Verarbeitung der personenbezogenen Daten wie Name und Vorname minimiert wird und nur für die Identifikation genutzt wird. Wahlkennzeichen sind eine häufig genutzte mögliche Umsetzung für die Identifikation von Wählenden. Der Wählende greift mithilfe seines Endgerätes auf das Onlinewahlssystem zu und kann nach erfolgreicher Authentifizierung seine Stimme als Onlinestimme abgeben. Im Anschluss wird die Stimme in der elektronischen Wahlurne gespeichert, bevor die Auswertung der Stimmen vollzogen wird. Das Onlinewahlssystem wertet die Wahl aus und stellt die Wahlergebnisse bereit.

Hierzu sind verschiedene Aspekte und Anforderungen an die Organisation zu beachten. Im Zentrum dieser allgemeinen Anforderungen steht die Erstellung eines IT-Sicherheitskonzepts nach BSI IT-Grundschutz. Im Anhang 1 (siehe 5.) wird der IT-Grundschutz im Detail näher erläutert.

Insgesamt wird für eine Onlinewahl ein Onlinewahlssystem mit Komponenten wie z.B.

Wählendenverzeichnis, Wählendenkennzeichen, Wählendenkennzeichen-Liste, elektronische Wahlurne, Archiv sowie weitere unterstützende Server benötigt. Damit eine Onlinewahl unter Betrachtung wesentlicher Sicherheitsaspekte gelingen kann spielt die Auswahl eines geeigneten Onlinewahlsystems eine entscheidende Bedeutung. Entsprechend muss das sorgfältig ausgewählt werden. Die sicherheitstechnischen Anforderungen an ein Onlinewahlssystem können hierbei im Rahmen der Produktabnahme beim Dienstleister bzw. Hersteller durch eine Produktzertifizierung gemäß CC-PP-0121 (2) geprüft werden (siehe 2.5).

Aufgrund dessen, dass der Client des Wählenden nicht Teil des Informationsverbundes Onlinewahl ist, kann diese Technische Richtlinie keine Vorgaben hinsichtlich des Clients machen. Jedoch sollte der Wahlvorstand im Rahmen einer Risikoanalyse den Schadcodebefall seitens des Clients mitbewerten. Dazu gehört auch eine Betrachtung anwendungsseitiger Maßnahmen, wie beispielsweise die Nutzung eines zweiten Devices für die Prüfung der Ende-zu-Ende Verifizierbarkeit, bei der Auswahl eines Onlinewahlprodukts. Daneben sollten Wahlberechnigte für die Teilnahme an einer Onlinewahl sensibilisiert werden. Dies kann z.B. durch die Aushändigung der Empfehlungen des BSI zur Absicherung des lokalen Rechners (Installation einer Firewall, eines Virenschanners usw.) mit den Wahlunterlagen und einen Hinweis auf die Sensibilität der Wahlunterlagen geschehen. Das BSI hat hierzu einen Handlungsleitfaden für Wählende veröffentlicht (13).

Zudem muss das Onlinewahlssystem zusätzlich auf seine Benutzbarkeit und Barrierefreiheit geprüft werden, sodass sichergestellt ist, dass das Onlinewahlssystem für jeden Wählenden bedienbar ist. Die Benutzbarkeit und Barrierefreiheit wird z.B. durch eine Zertifizierung nach Common Criteria nicht geprüft.

3.2 Vorbereitungsphase

3.2.1 Aspekte der Vorbereitungsphase

Für die Durchführung einer Onlinewahl sind neben der Selektion und Konfiguration des Onlinewahlsystems viele weitere Maßnahmen und Prozesse für die Onlinewahl vorzubereiten. Zum Teil unterstützt das Onlinewahlssystem Aufgaben der Vorbereitung, während andere Aufgaben dagegen vollständig außerhalb und ohne Unterstützung des Systems durchgeführt werden. Zur Vorbereitung einer Wahl gehören zum Beispiel:

- Festlegen der relevanten Termine für den Wahlzeitraum
- Vorbereiten oder Erstellen der Wahlkennzeichen bzw. eines Wählendenverzeichnisses
- Auswahl und Überprüfung des Onlinewahlsystems
- Ermitteln der Wahlkandidaten
- Erstellen der Wahllisten
- Vorbereiten oder Erstellen eines Stimmzettels für die Wahl
- Erstellung eines Löschkonzeptes

Erfassung der Wählenden

Ein wichtiger Aspekt der Vorbereitungsphase ist, dass die Nutzer eindeutig identifiziert werden. Aus diesem Grund muss das Vertrauensniveau zur Identifizierung der mit dem Onlinewahlssystem interagierenden Personen mit dem ermittelten Schutzbedarf korrespondieren. Soweit gesetzlich nicht anders vorgegeben, muss mindestens ein NORMALES Vertrauensniveau nach der Technischen Richtlinie TR-03107 (10) angenommen werden. Für eine angemessene Identifizierung des Nutzers empfehlen wir jedoch mindestens ein SUBSTANZIELLES Vertrauensniveau (BSI TR-03107-1) (14). Der elektronische Identitätsnachweis kann unter Verwendung des deutschen Personalausweises (gemäß PAuswG, 2009) (15), des elektronischen Aufenthaltstitels (gemäß AufenthG (16)) oder der eID-Karte (gemäß eIDKG (17)) zur elektronischen Identifizierung durchgeführt werden. Damit wird ein hohes Vertrauensniveau erreicht. Dabei muss die Identifizierung der Nutzer nicht Teil des Onlinewahlsystems sein. Daher ist dies nicht Teil der Zertifizierung nach CC-PP-0121 (2) (siehe dazu auch Kapitel 2.5).

Wenn die Daten des Onlinewählendenverzeichnis (OWV) und die WKZ nicht im Onlinewahlssystem selbst gepflegt werden, müssen diese in das Onlinewahlssystem übertragen werden. Für Abstimmungen oder Wahlen in kleinerem Umfang kann ggf. ein Wahlverzeichnis oder eine Liste der Teilnehmer der Abstimmung im Onlinewahlssystem selbst erstellt und gepflegt werden. In anderen Fällen wird das Wählendenverzeichnis aber nicht im Onlinewahlssystem erzeugt, sondern aus einem anderen Register heraus erstellt und in das Onlinewahlssystem übertragen. In beiden Fällen gelten die gleichen Anforderungen an Vertraulichkeit, Integrität und Verfügbarkeit der Daten. Abbildung 1 zeigt beispielhaft, wie die Kommunikationswege innerhalb des Onlinewahlsystems aussehen könnten. In Fall einer Erstellung außerhalb und einer Übertragung in das Onlinewahlssystem sollte das Onlinewählendenverzeichnis nach der Erstellung durch eine entsprechend der im Rechte- und Rollenkonzept festgelegten Rolle beim Wahlvorstand qualifiziert elektronisch signiert und mit einem qualifizierten Zeitstempel versehen werden. Zusätzlich muss vor dem Versand des Wählendenverzeichnisses online eine geeignete Inhaltsverschlüsselung nach BSI TR-02102-1 (18) erfolgen. Dies bietet einen zusätzlichen Schutz des OWVs gegen unberechtigte Kenntnisnahme.

Im Folgenden soll eine detaillierte Sicht auf die Anwendungsbestandteile und die Kommunikationswege geworfen werden, welche die wesentlichen Geschäftsprozesse einer Onlinewahl abbilden und unabhängig von der Art der Onlinewahl und dem eingesetzten Onlinewahlprodukt sind. Anwendungsbestandteile, die

Teil des Onlinewahlproduktes sind, können im Rahmen der Produktabnahme beim Dienstleister bzw. Hersteller durch eine Produktzertifizierung gemäß CC-PP-0121 (2) geprüft werden.

Abnahmekriterien für die Auswahl und Beschaffung des Onlinewahlsystems

Ein Abnahmeplan kann bei der Auswahl und Beschaffung des Onlinewahlsystems helfen und sollte vorab durch den Wahlvorstand erstellt werden. Dieser Abnahmeplan sollte folgende Aspekte beinhalten:

- Testarten (z.B. Funktionstest)
- Testfälle (z.B. Abgabe einer Stimme, Durchführung der individuellen Verifikation, etc.)
- Erwartete Ergebnisse (z.B. Bei Ausfüllen eines Stimmzettels auf gültige Weise und Bestätigen der Stimmabgabe erfolgt eine Rückmeldung des Systems über die erfolgreiche Abgabe. Informationen für individuelle Verifizierbarkeit werden zur Verfügung gestellt.)
- Freigabekriterien (z.B. Test zur Stimmabgabe, Verifizierbarkeit und Auszählung können erfolgreich durchgeführt werden. Logdateien werden vollständig erzeugt. Alle geforderten Logs und Konfigurationsdateien sind signiert.)
- Vorgehensweise bei Ablehnung der Freigabe (z.B. Sollte die Freigabe nicht erfolgen können, werden die Mängel behoben und die Tests werden vollständig wiederholt.)

Hinsichtlich der Abnahme des Informationssicherheits-Managementsystems (ISMS) und des Sicherheitskonzeptes empfehlen wir generell die Zertifizierung eines ISMS und eines IT-Sicherheitskonzeptes nach ISO 27001 auf Basis von IT-Grundschutz. Wenn keine Zertifizierung angestrebt wird, muss ein IS-Revisionsverfahren etabliert werden, bei dem regelmäßig und mindestens alle drei Jahre eine IS-Revision durchgeführt wird. Dabei muss der Leitfaden zur Informationssicherheitsrevision des BSI (19) beachtet werden.

Das Onlinewahlssystem muss durch geeignete IS-Penetrationstests und IS-Webchecks² hinreichend auf Schwachstellen getestet werden. Dabei wird überprüft, ob das im Sicherheitskonzept vorgegebene Sicherheitsniveau auch tatsächlich erreicht und gehalten wird. Hierfür bietet es sich an, ein Penetrationstest-Konzept zu erstellen, welches den BSI-Empfehlungen zu Penetrationstests (20) folgt. Entsprechende Tests können von einem durch das BSI zertifizierten IT-Dienstleister³ durchgeführt werden

Überprüfung des Onlinewahlsystems

Wenn bei der Überprüfung des Onlinewahlsystems Fehler auffallen, kann es notwendig sein, bestimmte Schritte der Vorbereitung zu wiederholen oder aufwändige Analysen zu betreiben, um die Fehlerursache zu finden und zu beheben. Hierzu wird empfohlen alle Schritte der Vorarbeiten mit ausreichend Vorlaufzeit einzuplanen, damit es bei Problemen in der Abnahme nicht zu Verzögerungen im Ablauf der Wahl kommt.

Integrität- und Authentizitätsüberprüfung des OWVs

Es besteht die Möglichkeit das OWV außerhalb des Onlinewahlsystems zu erstellen und dorthinein zu importieren oder das OWV direkt im Onlinewahlssystem anzulegen.

Wurde das Wählendenverzeichnis direkt im Onlinewahlssystem erstellt oder kann es nach dem Import weiter bearbeitet werden muss das Rechte- und Rollenkonzept regeln, wer für die Eintragung und Pflege der Daten von Wahlberechtigten in das Wählendenverzeichnis des Onlinewahlsystems verantwortlich ist.

Wurde das Wählendenverzeichnis außerhalb des Onlinewahlsystems abschließend erstellt und bearbeitet, so muss es für die weitere Bearbeitung gesperrt werden.

² Weitere Informationen sind auf der BSI Website zu finden, https://www.bsi.bund.de/DE/Themen/Cyber-Sicherheit/Dienstleistungen/ISPentest_ISWebcheck/ispentest_iswebcheck_node.html

³ Eine aktuelle Auflistung zertifizierter IT-Sicherheitsdienstleister in den Geltungsbereichen IS-Revision und IS-Penetrationstests finden sich auf der BSI Website, siehe https://www.bsi.bund.de/DE/Themen/ZertifizierungundAnerkennung/Stellen/IS_REV_PEN/IS_REV_Dienstleister/IS_REV_Dienstleister_node.html

Beim Import eines OWV darf dieses lediglich zur Integration des OWV in das Onlinewahlssystem entschlüsselt werden. Der Zeitpunkt der Entschlüsselung muss dabei erfasst und dokumentiert werden. Ein Rechte- und Rollenkonzept regelt die Verantwortlichkeiten für die Kryptographie und die Besitzer des privaten Schlüssels unter einem 4-Augen-Prinzip.

Um die Manipulationssicherheit des OWVs zu garantieren, sind die elektronische Signatur und der Zeitstempel des OWVs bei Überführung in das Onlinewahlssystem zu validieren. Dazu sind die öffentlichen Schlüssel der Wahlvorstände vor Einbindung des OWV sicher in das Onlinewahlssystem zu importieren. Dabei sind die jeweiligen Vorschriften der Kommunikationsübertragung zu berücksichtigen.

Verfügbarkeitsüberprüfung des Onlinewahlsystems

Die Anforderung an die Verfügbarkeit eines Onlinewahlsystems richtet sich nach dem festgelegten Schutzbedarf. Die konkreten Anforderungen müssen mithilfe von Service-Level-Agreements (SLA) mit dem Online-Dienstleister vorab vertraglich definiert werden. Es muss insbesondere darauf geachtet werden, dass die Anforderungen von Notfall- und Sicherheitsmanagement in den Verträgen berücksichtigt werden. Beispiele für zu treffende Vereinbarungen sind z.B.: Berichtspflichten des Dienstleisters, Reaktions- und Erreichbarkeitszeiten ggf. bis zu 24/7, etc.

Um die Verfügbarkeit des Onlinewahlsystems zu gewährleisten, sollten die IT-Systeme redundant ausgelegt werden. Sollte es zu einem Ausfall eines IT-Systems kommen, so kann ein anderes IT-System die Aufgaben übernehmen und die Fortführung der Wahl sicherstellen.

Monitoring des Onlinewahlsystems

Das Onlinewahlssystem sollte dauerhaft überwacht werden, um potenzielle Cyber-Angriffe zu erkennen und im Anschluss entsprechende Maßnahmen einleiten zu können. Im Vorfeld sollte definiert werden welche Sicherheitsmaßnahmen im Fall von Cyber-Angriffen dokumentiert und umgesetzt werden, um beispielsweise DDoS-Angriffe zu verhindern oder abschwächen. Dabei ist darauf zu achten, dass die Überwachung des Servers nicht zu einer Beeinträchtigung des Wahlgeheimnisses führen kann.

Verifizierbarkeit des Wahlergebnisses

Es muss die Möglichkeit gegeben werden, das Wahlergebnis nachvollziehen zu können. Das Ziel der Verifizierbarkeit ist es dem Wählenden die eigene Beteiligung an der Wahl und für jeden das Zustandekommen des Wahlergebnisses nachvollziehbar machen zu können. Zusätzlich gibt die Verifizierbarkeit den Wählenden die Möglichkeit, Vertrauen in die Verarbeitung von Onlinestimmen bis hin zur Auszählung des Wahlergebnisses zu gewinnen. Hierbei werden folgende Ausprägungen der Verifizierbarkeit betrachtet:

1. Der Wählende kann nachvollziehen, dass seine Stimme korrekt in die Wahlurne eingegangen ist (individuelle Verifizierbarkeit).
2. Jeder kann nachvollziehen, dass alle Stimmen korrekt zum Wahlergebnis zusammengerechnet wurden (universelle Verifizierbarkeit).
3. Es soll möglich sein, dass jeder feststellen kann, dass alle Stimmen von berechtigten Wählenden abgegeben wurden. (Verifizierbarkeit der Berechtigung).

Alle Punkte zusammen werden auch als Ende-zu-Ende Verifizierbarkeit bezeichnet.

Das BSI hat einen Handlungsleitfaden (21) veröffentlicht, der dabei unterstützt eine fundierte Entscheidung zum Einsatz von Verifizierbarkeit bei der eigenen Wahl zu treffen.

Ende-zu-Ende-Verifizierbarkeit erfordert eine Umsetzung im eingesetzten Onlinewahlprodukt. Informationen dazu, wie dies im PP-0121 umgesetzt ist finden sich in Kapitel 2.5.

Planung und Durchführung von Notfallübungen

Zur Sicherstellung eines geeigneten Notfallmanagements sollten vor der Durchführung einer Onlinewahl mindestens die folgenden Tests und Übungen aus dem Notfallmanagement (22) durchgeführt werden:

- Tests der technischen Vorsorgemaßnahmen
- Funktionstests
- Simulation von Szenarien

Damit werden unter anderem technische Vorsorgemaßnahmen, Sofortmaßnahmen, Wiederanlaufpläne, sowie die Kommunikation aller Beteiligten im Rahmen von Alarmierung und Krisenarbeit ausreichend getestet.

Sicherstellung der Mandantenfähigkeit

Wenn ein Onlinewahlssystem z.B. durch einen Anbieter als Dienstleistung zur Verfügung gestellt wird, dann muss in diesem Zusammenhang betrachtet werden, inwiefern das Onlinewahlssystem die verschiedenen Mandanten voneinander trennt. Die Mandantenfähigkeit beschreibt die Umsetzung des Mandantentrennungskonzepts zur getrennten Speicherung und Verarbeitung der Daten der einzelnen Mandanten, so dass nur der Mandant selbst sowie ausgewählte Personen Zugriff auf die Daten haben. Dies erfordert, dass mandantenabhängige und mandantenübergreifende Daten und Objekte initial getrennt werden. Für die Umsetzung dieser Mandantenfähigkeit des Onlinewahlsystems gibt es entsprechende Maßnahmen aus dem IT-Grundschutz zur Umsetzung (z.B. in den Bausteinen Cloud-Management und Outsourcing). Die Mandantentrennung muss mit einem angemessenen Sicherheitsniveau durchgeführt werden.

Prüfung und Freigabe des Onlinewahlsystems durch den Wahlvorstand

Das Onlinewahlssystem muss Mechanismen umsetzen, welche dem Wahlvorstand ermöglichen, die Einhaltung der spezifischen Vorgaben und Besonderheiten nach dem Einrichten des Onlinewahlsystems zu überprüfen und zu protokollieren.

Der Freigabeprozess sollte organisatorisch ein 4-Augen-Prinzip vorsehen. Nach der Freigabe müssen die freigegebenen Elemente vor unbefugten Veränderungen geschützt werden, um Manipulationen auszuschließen und die Integrität sicherzustellen.

3.2.2 Anforderungen an die Vorbereitungsphase

- | | |
|---------|---|
| WSW.1.B | Für Onlinewahlen oder -Abstimmungen SOLLTE durch die (Wahl-)Leitung eine geeignete Anwendung ausgewählt und eingesetzt werden. Sind die Anforderungen der (Wahl-)Leitung deckungsgleich mit denen des CC-PP-0121, SOLLTE auf eine zertifizierte Anwendung zurückgegriffen werden. |
| WSW.2.H | Der eigenverantwortliche Betrieb eines Onlinewahlproduktes SOLLTE bei Onlinewahlen, die mit einem Schutzbedarf hinsichtlich der Vertraulichkeit und Integrität mit „Hoch“ oder „Sehr hoch“ bewertet wurde, erwogen werden. Bei Einsatz eines Onlinewahlsystems als verteiltes System ist zu berücksichtigen, dass diese durch verschiedene Betreiber gehostet werden SOLLTEN. |
| WSW.3.B | <p>Bei Nutzung einer externen Betriebsdienstleistung oder einer Cloudlösung durch einen oder mehrere Anbieter SOLLTE dies spätestens in der Risikoanalyse besonders betrachtet werden. Dazu SOLLTEN folgende Leitfragen beantwortet werden:</p> <ul style="list-style-type: none"> • Wird die Anwendung in einer geteilten oder einer kundeneigenen Umgebung bzw. Infrastruktur betrieben? • Wie wird die Anbindung der Anwendung an die gewünschten Netze (z.B. Intranet der Organisation) umgesetzt? • Wo stehen die für die Anwendung genutzten Server (Welche Rechtsvorschriften gelten? Europäisches Recht?)? • Gibt es begründete Bedenken bezüglich des Datenschutzes an dem Standort des Rechenzentrums oder gegen den Betreiber (Gilt die DSGVO?)? |

- WSW.4.B Bei der Auswahl und Beschaffung des Onlinewahlsystems SOLLTE durch den Wahlvorstand ein Abnahmeplan erstellt werden. In einem Abnahmeplan SOLLTEN die durchzuführenden Testarten, Testfälle und die erwarteten Ergebnisse dokumentiert sein. Außerdem SOLLTE der Abnahmeplan die Freigabekriterien beinhalten. Es SOLLTE eine Vorgehensweise für die Situation festgelegt werden, wenn eine Freigabe abgelehnt wird.
- WSW.5.B Die Verfügbarkeit des Onlinewahlsystems richtet sich nach dem festgelegten Schutzbedarf. Konkrete Anforderungen hinsichtlich der Verfügbarkeit SOLLTEN mit dem Betriebsdienstleister über den Abschluss von Service-Level-Agreements (SLA) definiert werden. Es SOLLTE darauf geachtet werden, dass die Anforderungen von Notfall- und Sicherheitsmanagement in den Verträgen berücksichtigt werden (Siehe [NFM.1.6](#)).
- WSW.6.B Um die Verfügbarkeit des Onlinewahlsystems zu gewährleisten, SOLLTE dieses redundant ausgelegt werden. Aus diesem Grund SOLLTEN Maßnahmen zur Umsetzung von Redundanz geplant werden, um die Redundanz von IT-Systemen und Anwendungen bei einem Ausfall ausreichend zu gewährleisten. Hierbei SOLLTE auch die Internetanbindung des Webserver und weiterer IT-Systeme, wie etwa der Webanwendungsserver redundant ausgelegt werden.
- WSW.7.B Das Onlinewahlsystem SOLLTE ständig überwacht werden. Des Weiteren SOLLTEN Maßnahmen definiert, dokumentiert und umgesetzt werden, die DDoS-Angriffe verhindern oder die Auswirkungen abschwächen (Siehe SYS.1.1.A23). Dabei ist darauf zu achten, dass die Überwachung des Servers nicht zu einer Beeinträchtigung des Wahlgeheimnisses führen kann.
- WSW.8.B Die Konfiguration des Onlinewahlsystems MUSS freigegeben werden. Dabei sind die wesentlichen Einstellungen in Bezug auf die Wahldurchführung zu dokumentieren, wie z.B. der eingerichtete Wahlzeitraum und die im System konfigurierten Regeln und Bedingungen der Online-Stimmabgabe. Die freigegebenen Elemente MÜSSEN nach der Freigabe vor unbefugten Veränderungen geschützt werden. Außerdem SOLLTE der Freigabeprozess organisatorisch nach dem 4-Augen-Prinzip durchgeführt werden, um Manipulationen auszuschließen. Die freigegebene Konfiguration des Onlinewahlsystems SOLLTE durch den Wahlvorstand qualifiziert elektronisch signiert und mit einem qualifizierten Zeitstempel versehen werden. Damit wird eine unbemerkte Veränderung des Systems nach der Freigabe ausgeschlossen. Die Zuständigkeiten für die Freigabe MÜSSEN im Vorfeld im Rechte- und Rollenkonzept festgelegt werden.
- ISMS.1.1.B Ein IT-Sicherheitskonzept für den Geltungsbereich der Onlinewahl SOLLTE für ein vollständiges und zertifiziertes Informationssicherheitsmanagementsystem auf Basis von BSI IT-Grundschutz (12) erstellt werden.
- ISMS.1.2.B Die Definition des Informationsverbunds der Onlinewahl MUSS neben der eigentlichen Onlinewahl auch technisch unterstützte vorgelagerte Prozesse der Wahlvorbereitung, sofern diese im Verantwortungsbereich des Wahlvorstands liegen, mit aufnehmen. Dies betrifft z.B. Vorschlagslisten, Wahlkalender, Stimmzettelerstellung, sowie Wählendenverzeichnis und Wahlkennzeichen.
- ISMS 1.3.B Im IT-Sicherheitskonzept MÜSSEN sämtliche Schnittstellen betrachtet werden. Dies gilt für Schnittstellen zur manuellen Datenübertragung genauso wie für automatisierte Übertragung von Daten zwischen Systemen. Werden interne Prozesse und Aufgaben (z.B. Betrieb) durch einen Dienstleister wahrgenommen, dann SOLLTE sichergestellt werden, dass auch der Dienstleister BSI IT-Grundschutz (12) oder ISO 27001 (23) umgesetzt hat. Der Dienstleister kann die Umsetzung durch eine entsprechende Zertifizierung nachweisen.
- ISMS 1.4.B Es SOLLTE ein IT-Sicherheitskonzept nach BSI IT-Grundschutz für externe Systeme, welche für die Wahl relevante Inhalte liefern, vorliegen. Darüber hinaus SOLLTEN Prozesse zur

	Wahlvorbereitung, sofern diese im Verantwortungsbereich des Wahlvorstands liegen, mit in das IT-Sicherheitskonzept aufgenommen werden.
ISMS.2.B	Es SOLLTE eine Informationssicherheitsleitlinie gemäß der Anforderung des IT-Grundschutz Bausteins ISMS.1.A3 erstellt werden, die die wesentlichen Inhalte der Sicherheitsstrategie wiedergibt.
ISMS.3.B	Der Geltungsbereich der Wahl SOLLTE in der Leitlinie definiert sein.
ISMS.4.B	Der Geltungsbereich des ISMS SOLLTE alle Zielobjekte des Informationsverbundes für die Onlinewahlen und -Abstimmungen, wie in dieser Technischen Richtlinie betrachtet und die vom Wahlvorstand identifizierten IT-Systeme (SYS), Netze und Kommunikation (NET) sowie Räume und Gebäude (INF), welche für den Betrieb der Anwendungen zu Grunde liegen, umfassen. Sind Prozessverantwortlicher und Betreiber unterschiedlich, bspw. aufgrund des Einsatzes eines Dienstleisters, SOLLTE auch der Dienstleister ein IT-Sicherheitskonzept im Rahmen des ISMS nach BSI IT-Grundschutz oder nach DIN ISO/IEC 27001 umsetzen. Zusätzlich SOLLTEN geeignete Rollen- und Rechtekonzepte erstellt werden.
ISMS.5.B	Die Zuständigkeiten für den Informationssicherheitsprozess SOLLTEN definiert sein.
ISMS.6.H	Falls externe Systeme im Informationsverbund Verwendung finden, MUSS im eigenen Konzept auf die konkreten IT-Sicherheitskonzepte der externen Systeme verwiesen werden.
ALL.1.H	Die Einhaltung der relevanten Wahlgrundsätze bei vorbereitenden Maßnahmen außerhalb des Onlinewahlsystems MUSS, unabhängig davon, ob diese in anderen Systemen oder in Papierform vorgenommen werden, abgesichert und kontrolliert werden.
ALL.2.H	Im Rechte- und Rollenkonzept MUSS festgelegt werden, welche Rolle innerhalb des Wahlvorstands für die Durchführung und Umsetzung des Abnahmeplans sowie für die Freigabe zuständig ist. Für die Ergebnisse der Prüfung müssen Prüf- und Ergebnisprotokolle erstellt werden.
ALL.3.B	Bei Onlineabstimmungen SOLLTEN sämtliche interne sowie externe Bedingungen, wie der rechtliche Rahmen, im Vorfeld festgelegt und für alle sichtbar dokumentiert werden. Ist für den Zeitraum einer Abstimmung eine feste Zeit vorgesehen, SOLLTE diese exakt im Sinne eines Countdowns ermittelt werden.
PET.1.B	Es SOLLTE ein Penetrationstest-Konzept erstellt werden. Dabei MÜSSEN die BSI-Empfehlungen zu Penetrationstests (BSI-Studie "Durchführungskonzept für Penetrationstests", 2020;) umgesetzt werden. Im Penetrationstest-Konzept SOLLTEN neben den zu verwendenden Testmethoden auch die Erfolgskriterien dokumentiert werden. Der Penetrationstest SOLLTE nach den Rahmenbedingungen des Penetrationstest-Konzepts erfolgen. Die durch den Penetrationstest aufgefundenen Sicherheitslücken SOLLTEN klassifiziert und dokumentiert werden.
PET.2.H	Das Onlinewahlssystem MUSS durch geeignete IS-Penetrationstests und IS-Webchecks auf Schwachstellen getestet werden, ob das im Sicherheitskonzept vorgegebene Sicherheitsniveau auch tatsächlich erreicht und gehalten wird (diese Anforderung muss ggf an den Betreiber weitergegeben werden).
PET.3.H	Die Penetrationstests MÜSSEN durch das BSI oder einen vom BSI zertifizierten IT-Dienstleister durchgeführt werden. Vor der Freigabe des Onlinewahlsystems MÜSSEN die aus den Penetrations- und Webtests entstandenen Maßnahmen umgesetzt werden und die Penetrations- und Webtests DÜRFEN KEINE gravierenden Auffälligkeiten enthalten. Können

	nicht alle Schwachstellen beseitigt werden, MUSS in einer Risikoanalyse das Restrisiko dokumentiert werden.
NFM.1.1.B	Das Notfallmanagement SOLLTE nach dem BSI Standard 200-4 (BSI Notfallmanagement) (22) umgesetzt werden.
NFM.1.2.B	Der Geltungsbereich für das IT-Sicherheitskonzept zu Onlinewahlen SOLLTE für das Notfallmanagement übernommen werden. Falls in der Organisation bereits ein Notfallmanagement existiert, SOLLTE dieses um die kritischen Geschäftsprozesse der Onlinewahl erweitert werden.
NFM.1.3.B	Es SOLLTE eine Leitlinie für das Notfallmanagement erstellt werden.
NFM.1.4.B	Die Rollen und Zuständigkeiten für den Notfallmanagement-Prozess SOLLTEN definiert sein. Bei der Besetzung der Funktionen des Notfallmanagements SOLLTEN die besonderen Anforderungen bezüglich der Behandlung von Notfällen berücksichtigt und das Personal geeignet ausgewählt werden.
NFM.1.5.H	Im Rahmen des Notfallmanagements MÜSSEN mindestens Notfallvorsorgekonzept, Notfall-, Wiederanlauf- und Wiederherstellungspläne erstellt werden.
NFM.1.6.B	Ein Notfallhandbuch mit Szenarien und entsprechenden Sofortmaßnahmen SOLLTE erstellt werden.
NFM.1.7.B	Die besonderen Aspekte des Notfallmanagements SOLLTEN bei der Planung zukünftiger und vorhandener Outsourcing-Projekte für die Durchführung einer Onlinewahl sowie bei der Vertragsgestaltung berücksichtigt werden. Gleichwohl SOLLTEN ausgelagerte Geschäftsprozesse bzw. Teilprozesse an Dritte bei der Konzeption des Notfallmanagements berücksichtigt werden.
NFM.1.8.B	Es SOLLTE für alle kritischen Geschäftsprozesse, für die eine Risikoanalyse durchgeführt werden soll, auch Gefährdungen im Sinne des Notfallmanagements betrachtet werden, um die Notfallvorsorge entsprechend zu gestalten.
NFM.1.9.B	Maßnahmen aus dem Notfallvorsorgekonzept SOLLTEN geplant und umgesetzt werden, um die wahldurchführende Organisation sowie die Mitarbeitenden auf eine Not- oder Krisensituation vorzubereiten.
NFM.1.11.B	Für die Planung und Vorbereitung von Tests und Übungen SOLLTEN entsprechende Test- und Übungsdokumentationen erstellt werden.
NFM.1.12.B	Notfallvorsorgemaßnahmen und -management SOLLTEN regelmäßig auf ihre Wirksamkeit und Aktualität untersucht und ggf. angepasst werden. Werden im Rahmen der regelmäßigen Überprüfung Mängel oder Verbesserungspotential festgestellt, SOLLTEN die Maßnahmen oder Prozesse dahingehend angepasst werden.
NFM.2.B	In einer Business Impact Analyse (BIA) SOLLTEN mindestens die Geschäftsprozesse zur Durchführung einer Onlinewahl mit allen seinen Teilprozessen betrachtet werden, um als Grundlage eines Notfallkonzeptes zu dienen.
NFM.3.B	Es SOLLTEN für alle Bereiche des Notfallmanagements Tests geplant und regelmäßig wiederholt werden. Entsprechende gesetzliche Vorgaben für die Durchführung regelmäßiger Tests und Übungen MÜSSEN beachtet werden.

NFM.3.1.B	Zur Sicherstellung eines geeigneten Notfallmanagements SOLLTEN vor Durchführung einer Onlinewahl mindestens die folgenden Tests und Übungen aus dem Notfallmanagement durchgeführt werden: • Tests der technischen Vorsorgemaßnahmen • Funktionstests • Simulation von Szenarien Damit werden unter anderem technische Vorsorgemaßnahmen, Sofortmaßnahmen, Wiederanlaufpläne, sowie die Kommunikation aller Beteiligten im Rahmen von Alarmierung und Krisenarbeit ausreichend getestet.
NFM.4.B	Die Folgen für den Fall, dass die Daten des Onlinewahlsystems abgefließen sind und infolgedessen Verbindungen zwischen Wählenden und Ihren abgegeben Onlinestimmen hergestellt werden können, MÜSSEN vor der Wahl abgeschätzt und bewertet werden. Dies kann im Rahmen der Risikoanalyse oder einer Datenschutzfolgeabschätzung erfolgen.
AUTH.1	Für die Wahl der Identifizierungs- und Authentifizierungsmechanismen SOLLTEN die Vorgaben der Technischen Richtlinie 03107-1 „Elektronische Identitäten und Vertrauensdienste im E-Government“ beachtet werden. Wir empfehlen das gewählte Vertrauensniveau an dem Schutzbedarf der Wahl auszurichten.
IAM.1.B	Das Vertrauensniveau zur Identifizierung der Nutzer SOLLTE mit dem ermittelten Schutzbedarf korrespondieren. Soweit gesetzlich nichts anderes vorgegeben ist, MUSS mindestens ein NORMALES Vertrauensniveau nach der BSI Technischen Richtlinie TR-03107-1 (14) erreicht werden. Für eine angemessene Identifizierung des Nutzers wird jedoch empfohlen mindestens ein SUBSTANZIELLES Vertrauensniveau anzuwenden (Kapitel 2.3 („Vertrauensniveaus“)). Dieses Identifizierungsverfahren SOLLTE nach den Vorgaben für das entsprechende Vertrauensniveau (gemäß BSI TR-03107-1) durch das BSI bewertet sein und dieses Vertrauensniveau nachweisbar erreichen.
IAM.2.B	Das Verfahren zur elektronischen Identifizierung SOLLTE insbesondere die Anforderungen (gemäß BSI TR-03107-1) Kapitel 5 („Identifizierung“) für die Identifizierung der Person und (gemäß BSI TR-03107-1) Kapitel 4 („Authentisierungsverfahren“) für Authentisierung während der Anmeldung des Nutzers am Onlinewahlssystem erfüllen.
IAM.3.H	Für ein hohes Vertrauensniveau MUSS der elektronische Identitätsnachweis unter Verwendung des deutschen Personalausweises gemäß PAuswG (15), des elektronischen Aufenthaltstitels gemäß AufenthG (16) oder der eID-Karte gemäß eIDKG (17) für die Identifikation eingesetzt werden.
IAM.4.B	Für vorgelagerte und außerhalb des Onlinewahlsystems verarbeitete Prozesse und die dort verarbeiteten Daten SOLLTE im Rechte- und Rollenkonzept klar definiert sein, wer welche Rechte und Funktionen beim Zugriff und der Verarbeitung dieser Daten hat.
IAM.5.B	Eingesetzte Signaturen, Siegel und Zeitstempel sowie deren Validierung SOLLTEN die Anforderungen an qualifizierte Signaturen, Siegel und Zeitstempel der eIDAS Verordnung (24) erfüllen. Dazu KANN die BSI Leitlinie für digitale Signatur-/ Siegel-, Zeitstempelformate (BSI Leitlinie) (25) umgesetzt werden.
IAM.6.B	Der Zeitstempel SOLLTE auf einer korrekten Zeitquelle, die mit der koordinierten Weltzeit verknüpft ist, beruhen. Ein qualifizierter elektronischer Zeitstempel verknüpft Datum und Zeit mit den Daten, sodass die Möglichkeit der unbemerkten Veränderung der Daten nach vernünftigem Ermessen ausgeschlossen ist.

- IAM.7.B Gemäß den Anforderungen nach BSI TR-03107 (14) Kapitel 6 („Identifizierung eines Diensteanbieters“) SOLLTE die ausstellende Stelle des Wählendenverzeichnisses Online ihre Identität gegenüber dem Onlinewahlssystem auf dem Vertrauensniveau „Hoch“ nachweisen. Um einen Diebstahl durch das Versenden des OWV an einen gefälschten Empfänger zu vermeiden, SOLLTE auch die Identität des Onlinewahlsystems gegenüber der entsprechenden Stelle, auf Vertrauensniveau „Hoch“ nachgewiesen werden.
- IAM.8.H Vor dem Versand des Wählendenverzeichnisses Online SOLLTE eine geeignete Inhaltsverschlüsselung nach BSI TR-02102-1 (18) erfolgen. Damit wird das Onlinewählendenverzeichnis gegen unberechtigte Kenntnisnahme auf dem Transportweg geschützt. Die Entschlüsselung des OWV SOLLTE nur zur Integration des OWV in das Onlinewahlssystem erfolgen. Der Zeitpunkt SOLLTE dabei dokumentiert werden.
- IAM.9.B In einem Rechte- und Rollenkonzept SOLLTE geregelt werden, wer für die Verschlüsselung und Entschlüsselung des Wählendenverzeichnisses Online zuständig und somit im Besitz des privaten Schlüssels ist. Hierbei SOLLTE das 4-Augen-Prinzip Anwendung finden.
- IAM.10.B Bei der direkten Erstellung des Wählverzeichnisses im Onlinewahlssystem SOLLTE in einem Rechte- und Rollenkonzept geregelt werden, wer für die Eintragung und Pflege der Daten von Wahlberechtigten in das Wählendenverzeichnis des Onlinewahlsystems verantwortlich ist. Bei der Erstellung SOLLTE das 4-Augen-Prinzip Anwendung finden. Wurde das Wählendenverzeichnis abschließend erstellt und bearbeitet, SOLLTE es für die weitere Bearbeitung gesperrt werden.
- IAM.11.B Das Onlinewählendenverzeichnis SOLLTE nach der Erstellung, unabhängig davon ob außerhalb oder im Onlinewahlssystem, durch eine entsprechend nach dem im Rechte- und Rollenkonzept festgelegten Rolle beim Wahlvorstand qualifiziert elektronisch signiert und mit einem qualifizierten Zeitstempel versehen werden.
- KRY.1.B Es MÜSSEN Verfahren implementiert werden, um die Kommunikationswege und deren Integrität und Vertraulichkeit bei der Übertragung von Daten in das Onlinewahlssystem zu sichern. Für die Transportabsicherung sind die Vorgaben gemäß BSI TR-03116-4 (26) maßgeblich. Insbesondere SOLLTEN die Vorgaben aus Kapitel 2 („Vorgaben für SSL/TLS“) erfüllt werden.
- KRY.2.B Die inhaltliche Absicherung der Daten, die in das Onlinewahlssystem übertragen werden sollen (z.B. OWV oder Stimmzettel), MUSS mithilfe eines kryptographischen Verfahrens erfolgen. Für Verschlüsselung, Signatur und Zeitstempel MÜSSEN aktuelle kryptographische Methoden gemäß der BSI TR-02102-1 (18) eingesetzt werden
- KRY.3.B Für die Inhaltsverschlüsselung MÜSSEN sichere Verfahren für den Schlüsselaustausch genutzt werden.
- KRY.4.B Ein unbefugter Zugriff auf geheimes Schlüsselmaterial MUSS sowohl technisch als auch organisatorisch verhindert werden. Dabei MUSS sichergestellt werden, dass es vor missbräuchlicher Nutzung und Manipulation geschützt ist. Zur sicheren Schlüsselspeicherung SOLLTE die Verwendung entsprechend zertifizierter Hardware (Chipkarte, HSM) gewährleistet sein. Ein Kopierschutz SOLLTE sichergestellt sein.
- KRY.5.B Es SOLLTE sichergestellt werden, dass ein Schlüsselerückruf (Revocation) für die Schlüssel möglich ist. Im Falle eines Schlüsselerückrufs SOLLTE sichergestellt werden, dass die direkten

Kommunikationspartner unverzüglich darüber informiert werden. Ebenso SOLLTEN die Anforderungen gemäß der BSI Key Lifecycle Security Requirements (27) umgesetzt werden.

3.3 Durchführungsphase

3.3.1 Aspekte der Durchführungsphase

Nutzungsumgebung der Organisation

Wird ein Onlinewahlsystem im Arbeitgeberumfeld angeboten und kann dieses mit dienstlichen Mitteln genutzt werden, dann ist der Arbeitsplatz in einem IT-Sicherheitskonzept modellierbar. Der Arbeitsplatz muss dann entweder im Informationsverbund zur Onlinewahl oder in einem übergeordneten Informationsverbund der Organisation modelliert sein. Dafür werden im BSI IT-Grundschutz diverse Bausteine für Clientgeräte angeboten (SYS.2.1 – SYS.3.2.4 (BSI IT-Grundschutz, 2021)). Nähere Informationen zum IT-Grundschutz befinden sich im Kapitel 5.

Nutzungsumgebung im privaten Umfeld

Das BSI gibt für Bürger Empfehlungen zur Absicherung des lokalen Rechners heraus. Diese Empfehlungen umfassen unter anderem:

- Installation von Firewall, Virens Scanner und aller Sicherheitsupdates
- Abschalten aktiver Inhalte im Browser soweit möglich
- Abschalten über die Sitzungsdauer hinaus persistenter Cookies im Browser

Diese Auflistung ist nicht umfassend. Des Weiteren hat das BSI einen Handlungsleitfaden für Wählende veröffentlicht (13). Der Handlungsleitfaden sollten dem Wahlberechtigten mit den Wahlunterlagen zur Verfügung gestellt werden, sodass dieser für den Umgang mit den Wahlunterlagen und die Teilnahme an der Onlinewahl sensibilisiert wird.

Aufgrund dessen, dass der Client des Wählenden nicht Teil des Informationsverbundes Onlinewahl sein kann, kann diese Technische Richtlinie keine Vorgaben machen. Jedoch sollte der Wahlvorstand im Rahmen einer Risikoanalyse den Schadcodebefall seitens des Clients mitbewerten und bei der Auswahl eines Onlinewahlprodukts anwendungsseitige Maßnahmen, wie beispielsweise die Nutzung eines zweiten Devices für die Prüfung der Ende-zu-Ende Verifizierbarkeit, berücksichtigen. Zudem müssen die Sicherheitsanforderungen, die an das Onlinewahlsystem gestellt werden, auf ihre Benutzbarkeit und Barrierefreiheit geprüft werden, sodass sichergestellt ist, dass das Onlinewahlsystem für jeden Wählenden bedienbar ist.

Stimmabgabe per Onlinewahl

Es gibt unterschiedliche Schwierigkeiten, die während des Wahlzeitraums, insbesondere in Zusammenhang mit der Abgabe der Online-Stimme auftreten könnten. Mögliche Probleme, die in Zusammenhang mit der Onlinewahl während oder nach dem Wahlzeitraum auftreten können, sind unter anderem:

- Das Onlinewahlsystem oder ein Bestandteil des Onlinewahlsystems ist nicht verfügbar
- Fehler auf Online-Stimmzettel, im OWV oder bei den WKZ werden erst während des Wahlvorgangs gefunden
- Die Vertraulichkeit von Onlinestimmen vor Ablauf der Wahlfristen ist beeinträchtigt
- Die Integrität der Onlinestimmen oder des Onlinewahlverzeichnisses ist beeinträchtigt
- Zuordnung zwischen Identitäten und Online-Stimmen kann hergestellt werden

Grundsätzlich sollten bei Verfügbarkeitsproblemen die Sofortmaßnahmen und das Notfall- und Krisenmanagement greifen. Ist das Onlinewahlsystem dennoch nicht verfügbar, dann sollte dieses Problem im Zusammenhang mit dem gewählten Wahlzeitraum und den Gegebenheiten des Ausfalls betrachtet werden. Bei einem großzügig gewählten Wahlzeitraum und einer verhältnismäßig zum Wahlzeitraum kurzzeitigen Nicht-Verfügbarkeit zu einem vergleichbar weniger kritischen Zeitpunkt, kann dieser Ausfall

ggf. ohne weitere Maßnahmen hingenommen werden (z.B. bei einem Wahlzeitraum von mehreren Wochen und einer Ausfallzeit von 15 Minuten, relativ früh im Wahlzeitraum). Ist das Onlinewahlsystem aber z.B. bei einem Wahlzeitraum von ein Tag, kurz vor Ende der Wahl für 1-2 Stunden nicht verfügbar, dann sollten Maßnahmen zum Ausgleich erwogen werden. Dies könnte eine Verlängerung des Wahlzeitraums um eine angemessene Zusatzzeit sein, wobei die Bereitstellung der Information gegenüber dem Wählenden bei diesem Zeitraum zu berücksichtigen ist, oder im schlimmsten Fall eine Wiederholung der Wahl.

Werden während des Wahlzeitraums noch Fehler auf dem Online-Stimmzettel oder im OWV bzw. bei den WKZ entdeckt, dann sind die abgegebenen Onlinestimmen ggf. nicht gültig und/oder nicht vollständig. In diesem Fall sind die Beeinträchtigungen der Wahl durch den Wahlvorstand zu beurteilen und entsprechende Maßnahmen zu ergreifen. Ein Fehler im Online-Stimmzettel, der z.B. weiterhin die gültige Auszählung der Stimmen erlaubt kann ggf. ignoriert werden, ansonsten ist die Wahl mit dem korrigierten Stimmzettel bzw. den korrigierten Registern zu wiederholen.

Bei unberechtigten Zugriffen auf Onlinestimmen ist zu prüfen, ob diese trotz der vorgesehenen Verschlüsselung unberechtigt gelesen oder manipuliert werden konnten (z.B., weil das Schlüsselmaterial kompromittiert ist). Diese Bewertung muss im Einzelfall erfolgen. Kann ein Angriff auf die Integrität und damit eine Manipulation der Stimmen ausgeschlossen werden, muss eine Einschätzung der Auswirkungen erfolgen. Dabei sind die Auswirkungen durch den Verlust der Vertraulichkeit der Onlinestimmen vor Auszählung und den entsprechenden Handlungsmaßnahmen abzuschätzen. Wenn eine Beeinträchtigung der Integrität von Onlinestimmen festgestellt wird, dann sind abgegebene Stimmen manipuliert worden. Dieser Fall ist zusätzlich auch für das OWV relevant, da hier ggf. die Daten von Wählenden verändert oder das OWV und die WKZ erweitert wurden, um z.B. weitere, unberechtigte Onlinestimmen abgeben zu können. Jede Manipulation an Onlinestimmen, OWV oder WKZ sorgt dafür, dass die Wahlergebnisse ungültig werden. In diesem Fall muss der Wahlvorgang abgebrochen und das Onlinewahlsystem auf den Ursprung der Manipulationen hin untersucht werden. Die Wahl muss entweder nach abschließender Behebung gefundener Sicherheitslücken und vollständiger Kontrolle des Onlinewahlsystems oder über alternative Wege erneut durchgeführt werden.

Bei einer geheimen Wahl ist sicherzustellen, dass die Zuordnung einer Onlinestimme zu einem Wählenden nicht vorgenommen werden kann. Aufgrund der Sicherstellung der Vertraulichkeit sollte es nicht möglich sein, dass eine Verbindung zwischen den Identitäten der Wählenden und deren Stimmen herzustellen ist. Die Vertraulichkeit kann unter anderem über kryptografische Maßnahmen im Onlinewahlsystem sichergestellt werden.

3.3.2 Anforderungen an die Durchführungsphase

WSW.9.H Die Integrität eines freigegebenen Online-Stimmzettels MUSS durch eine qualifizierte Signatur sowie einen qualifizierten Zeitstempel durch eine entsprechend nach dem im Rechte- und Rollenkonzept festgelegten Rolle beim Wahlvorstand abgesichert sein.

WSW.10.H Wenn es im Rahmen einer Wahl zu mehreren Wahlgängen kommt, KÖNNEN OWV und WKZ oder andere Identifizierungsmittel auch für neue Wahlgänge verwendet werden. Für die erneute Verwendung MÜSSEN folgende Aspekte berücksichtigt werden:

- Es DARF KEINEN Bezug zwischen den WKZ oder anderen Identifizierungsmitteln und bereits abgegebenen Onlinestimmen geben.
- Die elektronische Wahlurne und die elektronische Liste mit verwendeten WKZ MÜSSEN leer sein.
- Jeder Wahlgang MUSS systemseitig voneinander getrennt sein
- Die Daten des neuen Wahlvorgangs (z.B. Online-Stimmzettel, OWV, WKZ, etc.) MÜSSEN vor Beginn des nächsten Wahlgangs kontrolliert und für den Wahlgang freigegeben werden.

- WSW.11.B Um dem Nutzer Wahlfreiheit des eingesetzten lokalen Endgeräts zu geben und im Falle von Sicherheitswarnungen für bestimmte Systeme (z.B. Betriebssysteme oder Browser) Alternativen zu bieten, SOLLTEN Technologien nach dem Stand der Technik bevorzugt werden, die mit möglichst vielen Betriebssystemen und Browsern zusammenarbeiten.
- WSW.12.B Bei der Arbeit an besonders sensiblen Systemen SOLLTE bei der Personalauswahl besonders auf die Vertrauenswürdigkeit des ausführenden Personals geachtet werden. Davon ist insbesondere auch die Administration von Datenbanken betroffen, da hier üblicherweise alle Daten eines Systems persistiert werden.
- WSW.13.H Wenn das Wahlsystem trotz Notfall- und Krisenmanagements nicht verfügbar ist, MÜSSEN die Auswirkung und Tolerierbarkeit auf den Wahlvorgang- und Zeitraum analysiert werden. Sollte die anzuwendende Verordnung nicht anwendbar sein, MUSS dies durch den Wahlvorstand bewertet werden.
- WSW.14.B Wenn Fehler während des Wahlzeitraums auf dem Online-Stimmzettel oder im OWV bzw. bei den WKZ oder anderen Identifizierungsmitteln entdeckt werden, SOLLTE die Beeinträchtigung der Wahl hinsichtlich der Ungültigkeit oder Unvollständigkeit der Onlinestimmen durch den Wahlvorstand beurteilt und entsprechende Maßnahmen ergriffen werden.
- NFM.1.10.B Die Arbeit des Krisenstabs während der Notfall- oder Krisenbewältigung SOLLTE revisionssicher in einem Einsatztagebuch dokumentiert werden.
- LOG.1.H Der Ablauf der Onlinewahl MUSS protokolliert werden. Dabei MUSS der Mindeststandard des BSI zur Protokollierung und Detektion von Cyberangriffen (28) umgesetzt werden.

3.4 Auswertungsphase

3.4.1 Aspekte der Auswertungsphase

Bei der Ermittlung des Onlinewahlergebnisses wird die elektronische Wahlurne ausgewertet und gibt das Onlinewahlergebnis aus. Folgende Schritte müssen bei der Auswertung der Wahl durchlaufen werden. Sofern eine WKZ-Liste der online abgegebenen Stimmen existiert ist diese miteinzubeziehen:

1. Versiegelung der elektronischen Wahlurne

Die elektronische Wahlurne (und falls vorhanden die WKZ-Liste der online abgegebenen Stimmen) wird unmittelbar nach Ablauf des Wahlzeitraums versiegelt. Eine qualifizierte elektronische Signatur oder ein qualifiziertes elektronisches Siegel muss über alle in der Wahlurne gespeicherten Stimmen gebildet werden. Zusätzlich ist diese mit einem qualifizierten Zeitstempel zu versehen.

2. Entschlüsseln der Onlinestimmen und Ermitteln der Ergebnisse

Die Onlinestimmen liegen verschlüsselt vor. Damit die Onlinestimme nicht bereits vor der Auszählung entschlüsselt werden muss, müssen spezifische kryptografische Verfahren für die Auszählung der Stimmen eingesetzt werden. Wird beispielsweise eine semi-homomorphe Verschlüsselung genutzt, so kann dies die Auszählung der Stimmen, ohne dass sie vollständig entschlüsselt werden, ermöglichen. Bei dieser Methode ist zusätzlich der ordnungsgemäße Ablauf der Auszählung der Stimmen mit zu überprüfen. Dies kann z.B. mit Zero-Knowledge-Proofs erreicht werden.

3. Archivierung der elektronischen Wahlurne sowie weiterer zur Verifikation des Wahlergebnisses notwendiger Daten

Es ist eine Kopie der elektronischen Wahlurne (und falls vorhanden der WKZ-Liste der online abgegebenen Stimmen), sowie ein Paket mit den zur Verifikation im Rahmen der Ende-zu-Ende-Verifizierbarkeit

notwendigen Daten durch den Wahlvorstand außerhalb des Onlinewahlsystems sicher zu archivieren. Die Abbildung 1: Beispielhafter Kommunikationsplan illustriert beispielhaft die Kommunikationsverbindung zum Archiv. Diese Kopien dienen dazu das Ergebnis auch zu einem späteren Zeitpunkt erneut verifizieren zu können. Durch die vorherige Archivierung der elektronischen Wahlurne (und falls vorhanden der WKZ-Liste der online abgegebenen Stimmen) soll zudem sichergestellt werden, dass die Daten für eine spätere Wiederholung unverfälscht erhalten bleiben.

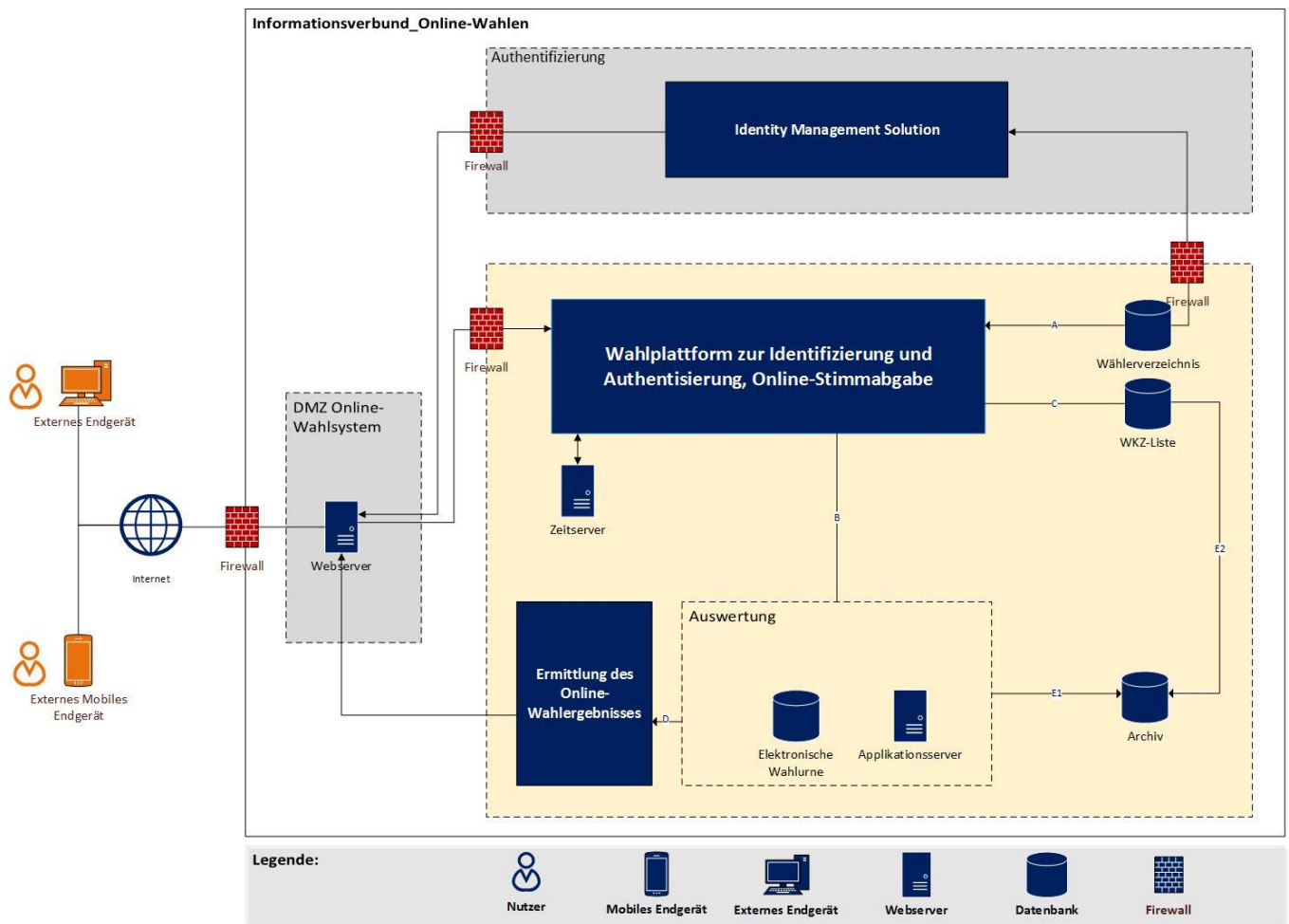


Abbildung 1: Beispielhafter Kommunikationsplan

4. Wahl Niederschrift erstellen

Die Wahl Niederschrift muss als Bestandteil des Informationsverbundes Onlinewahl entsprechend abgesichert werden.

3.4.2 Anforderungen an die Auswertungsphase

- NFM.5.H Bei unberechtigten Zugriffen auf Onlinestimmen MUSS geprüft werden, ob diese trotz der vorgesehenen Verschlüsselung unberechtigt gelesen oder manipuliert werden konnten (z.B., weil das Schlüsselmaterial kompromittiert ist). Diese Bewertung MUSS im Einzelfall erfolgen. Kann ein Angriff auf die Integrität und damit eine Manipulation, ausgeschlossen werden, MUSS abgeschätzt werden, welche Auswirkungen durch den Verlust der Vertraulichkeit der Onlinestimmen vor Auszählung zu erwarten sind und entsprechend gehandelt werden.
- NFM.6.H Wenn eine Beeinträchtigung der Integrität von Onlinestimmen, des OWV oder des WKZ oder eines anderen genutzten Identifizierungsmittels festgestellt wird, MUSS der Wahlvorgang abgebrochen und die Lage bewertet werden. Das Onlinewahlsystem MUSS auf den Ursprung der Manipulationen untersucht werden. Im Anschluss MUSS der Wahlvorstand im Einzelfall prüfen, ob und in welcher Form (digital oder analog) eine Neuwahl durchgeführt werden soll.

All.4.H	Nach dem Export MUSS die signierte und mit einem Zeitstempel versehene Kopie der elektronischen Wahlurne bzw. der WKZ-Liste der online abgegebenen Stimmen durch den Wahlvorstand außerhalb des Onlinewahlsystems sicher archiviert werden. Diese Kopie kann für eine spätere Verifizierung des Ergebnisses, das im Onlinewahlssystem ermittelt wird, genutzt werden.
ALL.5.H	Mit der Ermittlung des Wahlergebnisses DARF NICHT begonnen werden, bevor keine Beeinträchtigung der Grundwerte Vertraulichkeit und Integrität festgestellt worden ist und die Archivierung der elektronischen Wahlurne sowie der WKZ-Liste der online abgegebenen Stimmen abgeschlossen ist.
ALL.6.H	Die Wahlniederschrift MUSS als Bestandteil des Informationsverbundes Onlinewahl entsprechend abgesichert werden. Sie MUSS nach Fertigstellung mit einer qualifizierten elektronischen Signatur oder einem qualifizierten elektronischen Siegel versehen werden.
Prot.1.B	Damit die Protokolldaten/Logfiles gegen Veränderungen und Austausch geschützt sind, SOLLTEN diese beweissicher abgelegt und aufbewahrt werden. Daher MÜSSEN Protokolldaten mit einer qualifizierten elektronischen Signatur und einem qualifizierten Zeitstempel versehen werden.
Arch.1.H	Die langfristige Beweiserhaltung von qualifiziert elektronisch signierten, gesiegelten oder zeitgestempelten Daten wird im Vertrauensdienstgesetz (29) geregelt. Dazu KANN ein nach der BSI Technischen Richtlinie zur Beweiswerterhaltung kryptographisch signierter Dokumente (TR-ESOR) (TR-03125) (30) zertifiziertes Produkt eingesetzt werden.
Arch.2.B	Es SOLLTEN mindestens die folgenden Dokumente aufbewahrt werden. • Die signierten Protokolle des Onlinewahlsystems • Der für die Wahl genutzte und signierte Online-Stimmzettel • Das für die Wahl genutzte und signierte OWV und die WKZ • Das signierte Freigabeprotokoll des Onlinewahlsystems • Die vollständige und signierte WKZ-Liste abgegebener Onlinestimmen • Die vollständige und signierte elektronische Wahlurne • Das signierte Wahlergebnis und die Niederschrift • Das signierte Vernichtungsprotokoll nach Löschen der Daten aus dem Onlinewahlssystem • Das Paket mit den zur Verifikation im Rahmen der Ende-zu-Ende-Verifizierbarkeit notwendigen Daten

3.5 Nachbereitungsphase

3.5.1 Aspekte der Nachbereitungsphase

Die Nachbereitungsphase sieht Aufgaben, wie die fristgerechte Archivierung sowie Löschung von Daten vor. Hierfür ist ein Löschkonzept zu erstellen, das auf den einschlägigen Gesetzen und Richtlinien beruht (z.B. DSGVO). Ein Vernichtungsprotokoll hat die irreversible Löschung der Daten bei den Wahlverantwortlichen als auch bei deren Dienstleistern zu protokollieren.

3.5.2 Anforderungen an die Nachbereitungsphase

LOG.2.H	Ein Löschkonzept MUSS zur Sicherstellung der Archivierungsfristen und der anschließenden Löschung erstellt werden.
LOG.3.H	Ein Vernichtungsprotokoll MUSS bei der irreversiblen Löschung von Daten bei den Wahlverantwortlichen als auch für deren Dienstleister erstellt werden.

4 Schlusswort

Die vorliegende Technische Richtlinie wird weiterhin aktualisiert und gepflegt. Besonders hilfreich sind dabei Rückmeldungen von Wahlvorständen, die die Technische Richtlinie in ihrer bisher veröffentlichten Version angewandt haben. Damit soll sichergestellt werden, dass diese Technische Richtlinie den Stand der Technik berücksichtigt und gleichzeitig adressatengerecht bei der Umsetzung von Onlinewahlen unterstützt.

Möchten Sie Informationen rund um das Thema Onlinewahl erhalten oder möchten Sie uns Rückmeldung zu diesem oder anderen BSI-Dokumenten zum Thema Onlinewahl geben, melden Sie sich gern unter online-wahlen@bsi.bund.de.

5 Anhang 1: BSI IT-Grundschutz bei Onlinewahlen

5.1 Umsetzungshinweise zum BSI IT-Grundschutz

Bei der Erstellung eines IT-Sicherheitskonzepts nach IT-Grundschutz muss der Geltungsbereich, -auch Informationsverbund genannt- festgelegt werden, für den das IT-Sicherheitskonzept erstellt wird.

Der Informationsverbund für Onlinewahlen und -Abstimmungen beinhaltet das Onlinewahlprodukt (hierzu kann das BSI-CC-PP-0121 (2) genutzt werden), den Betrieb und den ggf. damit beauftragten Dienstleister, die organisatorischen Rahmenbedingungen wie Prozesse und Schlüsselmanagement und die Schnittstellen zum Onlinewahlprodukt.

Die IT-Grundschutz-Sicherheitskonzeption nach BSI-Standard 200-2 (11) sieht im Schritt der Strukturanalyse vor, die notwendigen Geschäftsprozesse (GP), Anwendungen (AW), IT-Systeme (SYS), Netze und Kommunikation (NET) und Räume und Gebäude (INF) eines Informationsverbunds als Zielobjekte in einer Bestandsanalyse aufzunehmen. Hierbei muss abgegrenzt werden, welche Zielobjekte für den Informationsverbund und den damit betrachteten Geltungsbereich relevant sind und welche ggf. aus einem anderen Geltungsbereich kommen und dort betrachtet werden müssen.

Bei der Schutzbedarfsfeststellung wird zunächst der Schutzbedarf für die Zielobjekte bestimmt, indem die möglichen Schäden bei einer Verletzung der Vertraulichkeit, der Integrität und der Verfügbarkeit nachvollziehbar eingeschätzt werden. Die Vertraulichkeit beschäftigt sich damit, dass Daten nur denen bekannt werden, für die sie auch bestimmt sind. Die Integrität wiederum beschäftigt sich mit dem Schutz von Daten vor unbefugter Veränderung. Die Verfügbarkeit beschäftigt sich mit der Erreichbarkeit von Daten innerhalb eines Zeitraums, für den dieses gewährleistet sein soll.

Für Onlinewahlen kann eine Verletzung der Schutzziele Vertraulichkeit, Verfügbarkeit und Integrität bedeuten, dass das Wahlergebnis ungültig ist und somit wiederholt werden muss. Beispiele für die Verletzung dieser Schutzziele sind:

- Vertraulichkeit: Onlinestimmen werden vor dem Ende der Wahl aus der elektronischen Wahlurne entnommen.
- Integrität: die Onlinestimmen werden ausgetauscht.
- Verfügbarkeit: das Onlinewahlssystem ist über einen kritischen Zeitraum nicht erreichbar.

Die Beschreibung der Geschäftsprozesse sowie die Feststellung des Schutzbedarfs obliegen den Prozessverantwortlichen. Nach Festlegung der Schutzbedarfe für die Geschäftsprozesse erfolgt nach dem Top-Down-Prinzip die Vererbung des Schutzbedarfes auf die darunter liegenden Schichten wie Anwendungen, IT-Systeme usw. Dabei vererbt ein Geschäftsprozess im Wesentlichen seinen Schutzbedarf auf eine oder mehrere Anwendungen. Bei der weiteren Ermittlung des Schutzbedarfs eines Objektes müssen die möglichen Schäden der relevanten Teilobjekte in ihrer Gesamtheit betrachtet werden.

Der ermittelte Schutzbedarf ist für die weitere Umsetzung bzw. Schritte des IT-Grundschutzes ausschlaggebend, u. a. zur Durchführung einer Risikoanalyse.

Die IT-sicherheitstechnischen Anforderungen für die Zielobjekte des definierten Informationsverbundes setzen sich aus den folgenden Quellen zusammen:

- Die entsprechende Verordnung bzw. Rechtsgrundlage über die technischen und organisatorischen Vorgaben für die Durchführung einer Onlinewahl oder Abstimmung
- BSI Technische Richtlinie BSI TR-03169 IT-sicherheitstechnische Anforderungen zur Durchführung einer Onlinewahl (vorliegendes Dokument)
- BSI CC-PP-0121-2024 Common Criteria Protection Profile – for e-voting systems for non-political elections
- IT-Grundschutzmethodik nach BSI-Standard zur Absicherung des Informationsverbundes gemäß Schutzbedarfsfeststellung

Werden Bestandteile oder Arbeiten, die im definierten Informationsverbund liegen, an einen Dienstleister übertragen ist nachzuweisen, dass die Schritte gemäß BSI IT-Grundschutz erfolgt sind und vom Prozessverantwortlichen überprüft wurden.

Wir empfehlen grundsätzlich bei informationsverarbeitenden Tätigkeiten einer Organisation die Einführung eines ISMS und die Erstellung eines IT-Sicherheitskonzeptes, um die sichere und sachgerechte Verarbeitung von Informationen zu gewährleisten. Gibt es ein bestehendes ISMS, kann der Informationsverbund für das Onlinewahlprodukt dort integriert werden.

5.1.1 Durchführung von BSI IT-Grundschutz

In diesem Kapitel und den folgenden Unterkapiteln wird die Umsetzung von BSI-IT-Grundschutz entsprechend der Standards 200-1, 200-2, 200-3 und 200-4 skizziert. Es wird soweit möglich auf Besonderheiten in Bezug auf Onlinewahlen eingegangen. Eine vollständige und ausführliche Beschreibung befindet sich in den eben genannten BSI-Standards (12), (22).

Für die Durchführung von IT-Grundschutz gibt es eine Reihe von Tools, die bei der Erfassung, Bearbeitung und Dokumentation der einzelnen Bearbeitungsschritte unterstützen und die die Erstellung und Pflege von aufwändigen und manchmal auch unübersichtlichen Dokumenten überflüssig machen. Eine Liste von Tools finden Sie auf der BSI-Webseite⁴.

Zu Beginn der Erstellung eines IT-Sicherheitskonzeptes nach BSI IT-Grundschutz muss der Geltungsbereich, der sogenannte Informationsverbund, festgelegt werden. Für das Thema Onlinewahlen muss der Informationsverbund alle Bestandteile der Onlinewahl beinhalten, sofern diese im Verantwortungsbereich der durchführenden Organisation liegen. Schnittstellen und Kommunikationsbeziehungen zu Prozessen oder Systemen aus anderen Bereichen müssen aber ebenfalls betrachtet werden. Den Betrieb und den Einsatz einer bestimmten Software verantwortet die nutzende Organisation. Wenn z.B. eine Information durch eine andere Organisation erzeugt und dann in den Informationsverbund übertragen wird, dann kann die Erstellung dieser Information nicht betrachtet werden. Die Art und Weise der Übertragung und die weitere Verarbeitung im Informationsverbund müssen allerdings betrachtet werden.

Das Informationssicherheitsmanagement (ISMS) dient als übergeordnete Struktur innerhalb welcher der Informationssicherheitsprozess durchgeführt werden kann. Ein wesentlicher Faktor bei einem ISMS ist die Gesamtverantwortung der Leitung. Für die Initiierung des Informationssicherheitsprozesses muss eine entsprechende Strategie entwickelt werden, in deren Rahmen Regeln, Ziele, Verantwortlichkeiten, Prozesse und Strukturen für die Informationssicherheit der Organisation definiert sind. Dies legt man in der Informationssicherheitsleitlinie fest.

Der Aufbau eines ISMS ist im Rahmen der Erstellung eines IT-Sicherheitskonzeptes nach BSI IT-Grundschutz möglich. Im IT-Grundschutz-Kompendium gibt es dazu insbesondere den Baustein ISMS.1 Sicherheitsmanagement (5).

Der IT-Grundschutz ist grundsätzlich sehr flexibel anwendbar. Ein Informationsverbund kann mit dem IT-Grundschutz behandelt werden, wenn er sich gerade im Aufbau befindet, aber auch wenn er schon länger existiert. Außerdem gibt es für verschiedene Bedarfe unterschiedliche Herangehensweisen der Absicherung. Der Grundschutz kennt die Basis-, die Kern- und die Standardabsicherung. Im Folgenden gehen wir von

⁴ https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/Alternative-IT-Grundschutztools/alternative-it-grundschutztools_node.html

einer Standardabsicherung für einen Informationsverbund zum Thema Onlinewahlen aus.

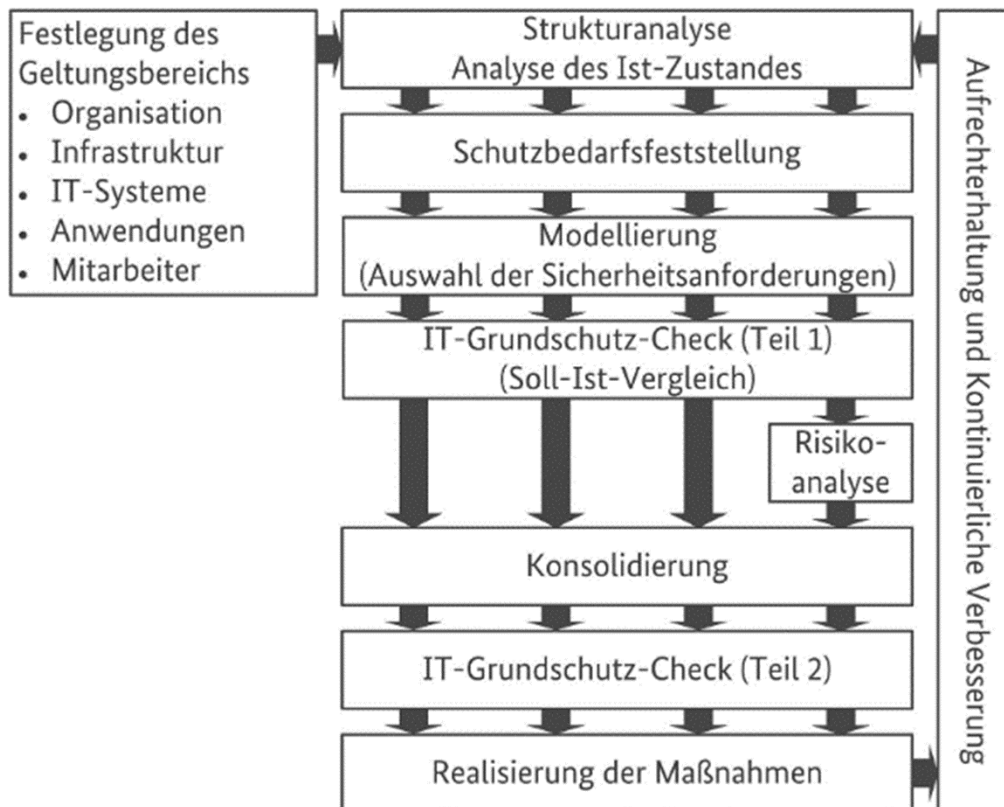


Abbildung 2: Vorgehen BSI IT-Grundschutz

Abbildung 2 zeigt unter anderem den erneuten Durchlauf des BSI IT-Grundschutz zur Aufrechterhaltung und kontinuierlichen Verbesserung. Dies ist insbesondere wichtig für Informationsverbünde, die bereits über einen längeren Zeitraum bestehen, um z.B. die Vollständigkeit, die Aktualität und Wirksamkeit von den einzelnen Bestandteilen des IT-Grundschutz regelmäßig zu überprüfen.

5.1.1.1 IT-Sicherheitskonzept

Zur Vorgehensweise bietet der IT-Grundschutz verschiedene Modelle der Absicherung eines Informationsverbunds. Es gibt die Basis-, die Kern- und die Standardabsicherung. Eine Basisabsicherung dient einer breiten und grundlegenden Erstabsicherung eines Informationsverbunds, die dann in weiteren Schritten zu einer vollständigen Absicherung ausgebaut werden kann. Eine Kernabsicherung hat zum Ziel zuerst die wichtigsten bzw. kritischsten Geschäftsprozesse eines Informationsverbundes abzusichern und dies dann in weiteren Schritten davon ausgehend zu erweitern. Die Standardabsicherung ist die standardmäßige und vollständige Absicherung eines Informationsverbunds. Da Onlinewahlen an sich als wichtiger Geschäftsprozess zu sehen sind, sollte für einen Informationsverbund zu Onlinewahlen direkt die Standardabsicherung (Abbildung 2: Vorgehen BSI IT-Grundschutz) durchgeführt werden.

Die Strukturanalyse dient der Vorerhebung von Informationen, die für die weitere Vorgehensweise in der Erstellung eines Sicherheitskonzepts nach IT-Grundschutz benötigt werden. Dabei geht es um die Erfassung der Bestandteile (Geschäftsprozesse, Informationen, Anwendungen, IT- und ICS-Systeme, Räume, Kommunikationsnetze), die zur Betrachtung des Geltungsbereichs benötigt werden, sowie deren Zusammenspiel.

Auf Basis der Strukturanalyse muss eine Schutzbedarfsfeststellung durchgeführt werden. Hier wird ermittelt, welcher Schutz für die in der Strukturanalyse identifizierten Zielobjekte ausreichend und angemessen ist. Dabei werden die zu erwartenden (Folge-)Schäden für die Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit betrachtet und in die drei Schutzbedarfskategorien „normal“, „hoch“ und „sehr hoch“ eingeteilt.

5.1.1.2 Strukturanalyse

Bei der Strukturanalyse geht es um die Erfassung aller Bestandteile eines Informationsverbunds, wobei im IT-Grundschutz im Wesentlichen zwischen Geschäftsprozessen, Informationen, Anwendungen, IT- und ICS-Systemen, Räumen, Kommunikationsnetzen unterschieden wird.

Die Strukturanalyse kann man mit der Analyse der Geschäftsprozesse und Informationen eines Informationsverbunds beginnen, um von dort aus die von den Geschäftsprozessen betroffenen Anwendungen zu identifizieren. Im nächsten Schritt kann man dann die IT-Systeme ermitteln, auf denen die Anwendungen betrieben werden, um dann wiederum zu ermitteln, in welchen Räumen und Gebäuden die IT-Systeme stehen und welche Netze diese angebunden haben. Diese Vorgehensweise ist der Standard, da bei der Schutzbedarfsfeststellung in gleicher Reihenfolge vorgegangen wird. Alternativ kann bei Informationsverbünden, deren Anwendungslandschaft in der Analyse abstrakt und schwer zu identifizieren ist, mit der Aufnahme der IT-Systeme begonnen werden, um von diesen ausgehend zu ermitteln, welche Anwendungen darauf betrieben werden etc.

Der Aufbau der genutzten Netzinfrastruktur muss mithilfe eines Netzplans erfasst und dokumentiert werden.

Um die Strukturanalyse und die anschließende Arbeit mit den identifizierten Zielobjekten zu vereinfachen, können hier gleichartige⁵ Zielobjekte zusammengruppiert werden. Hat man zum Beispiel mehrere IT-Systeme, die denselben Zweck erfüllen und auf denen dieselben Geschäftsprozesse und Anwendungen verarbeitet werden, so muss man die Schutzbedarfsfeststellung und Modellierung und ggf. die Risikoanalyse nicht für jedes dieser Systeme einzeln machen. Es muss allerdings darauf geachtet werden, dass die für die Gruppe von Zielobjekten herangezogenen Bausteine und Anforderungen auf allen Zielobjekten der Gruppe gleichermaßen umgesetzt werden.

Für die nachfolgende Schutzbedarfsfeststellung ist vor allen Dingen wichtig, dass auch die Zusammenhänge zwischen den Geschäftsprozessen, Anwendungen, IT-Systemen, Netzen und der Infrastruktur erfasst werden, da diese Abhängigkeiten zur Vererbung von Schutzbedarfen führen.

Auf der BSI-Webseite⁶ stehen Muster zur Strukturanalyse im Bereich Onlinewahlen zur Verfügung.

5.1.1.3 Schutzbedarfsfeststellung

Bei der Schutzbedarfsfeststellung wird für jedes Zielobjekt des Informationsverbunds bestimmt, welche Schadenshöhe in Bezug auf eine Verletzung der Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit zu erwarten ist. Die Einteilung erfolgt nach der Einstufung in eine der Schutzbedarfskategorien „normal“, „hoch“ oder „sehr hoch“. Im IT-Grundschutz wird zur qualitativen Bewertung anhand der Schutzbedarfskategorien jeweils betrachtet, wie die Auswirkung der Schadensszenarien Verstoß gegen Gesetze/Vorschriften/Verträge, Beeinträchtigung des informationellen Selbstbestimmungsrechts, Beeinträchtigung der persönlichen Unversehrtheit, Beeinträchtigung der Aufgabenerfüllung, negative Innen- oder Außenwirkung oder finanzielle Auswirkungen in Bezug auf die jeweilige Schutzkategorie zu bemessen sind. Diese sollten auf die Gegebenheiten des zu Grunde liegenden Informationsverbunds angepasst werden.

Auf der BSI-Webseite⁶ stehen Muster zur Festlegung der Schutzbedarfskategorien im Bereich Onlinewahlen zur Verfügung.

Sind die Schutzbedarfskategorien definiert, kann mit der Schutzbedarfsfeststellung für Geschäftsprozesse und den darin verarbeiteten Informationen begonnen werden. Dabei wird für jeden Geschäftsprozess ermittelt, welche Schutzbedarfskategorie in Bezug auf die Schutzziele Vertraulichkeit, Integrität und

⁵ Gleicher Typ, mit ähnlichen Aufgaben, ähnlichen Rahmenbedingungen und gleichem Schutzbedarf.

⁶ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

Verfügbarkeit jeweils zutrifft. Es ist zu klären, welche Schwere in einem Schadensfall bei einem der Schadensszenarien zu erwarten ist, wenn die im Geschäftsprozess verarbeiteten Daten bekannt werden, verändert werden oder für einen bestimmten Zeitraum nicht mehr zur Verfügung stehen. Entsprechend der vorher definierten Bandbreite von Auswirkungen der Schadensszenarien lässt sich dann eine Schutzbedarfskategorie ermitteln. Hierbei ist entsprechend dem Maximumprinzip vorzugehen, das heißt, wenn auf die verschiedenen Schadensszenarien für eins der Schutzziele unterschiedliche Schutzbedarfskategorien zugeordnet werden, muss hier immer die höchste Schutzbedarfskategorie für das Schutzziel ausgewählt werden.

Hat man diese Zuordnung für alle Geschäftsprozesse durchgeführt, kann man den Schutzbedarf auf anliegenden/abhängigen Komponenten aus der Strukturanalyse vererben. Eine Anwendung bekommt so den Schutzbedarf der Geschäftsprozesse, IT-Systeme den Schutzbedarf der Anwendungen, die auf ihnen betrieben und/oder verarbeitet werden und Netze und Räume den Schutzbedarf der IT-Systeme, die sie nutzen bzw. die dort untergebracht sind. Wenn bei dieser Vererbung ein Zielobjekt den Schutzbedarf von mehreren anderen Zielobjekten erbt, so wird auch hier das Maximumprinzip angewendet und der höchste Schutzbedarf für das jeweilige Schutzziel setzt sich durch. Zusätzlich können aber auch noch andere Effekte auftreten, die bei der Schutzbedarfsfeststellung zu beachten sind. Wenn viele Zielobjekte mit geringerem Schutzbedarf auf ein Zielobjekt vererben und der maximale Schutzbedarf von allen der geringere ist, kann es auf Grund der Ansammlung sinnvoll sein, trotzdem einen höheren Schutzbedarf anzuwenden, da bei der Verletzung eines Schutzziels alle vererbenden Zielobjekte auf einmal betroffen sind. Dies bezeichnet man als Kumulationseffekt. Konkret heißt das, dass wenn zum Beispiel auf einem Server viele Anwendungen laufen, die einen „normalen“ Schutzbedarf für Verfügbarkeit haben, es sein kann, dass man dem Server den Schutzbedarf „hoch“ zuweisen sollte, da der Ausfall vieler Anwendungen auf einmal in Summe zu einem größeren Problem werden könnte, als der Ausfall einer jeden Anwendung einzeln betrachtet. Verteilt man umgekehrt diese Anwendungen auf verschiedene Systeme kann durch den Verteilungseffekt der Schutzbedarf wieder auf das vorherige Niveau reduziert werden.

Auf der BSI-Webseite⁷ stehen Muster zur Schutzbedarfsfeststellung im Bereich Onlinewahlen zur Verfügung.

5.1.1.4 Modellierung

Bei der Modellierung werden alle notwendigen Bausteine für einen Informationsverbund für die weitere Bearbeitung ausgewählt. Im IT-Grundschutz-Kompendium (5) findet man eine Auflistung aller möglichen Bausteine und der zugeordneten Gefährdungen und Maßnahmen. Die Bausteine beinhalten auch jeweils eine Beschreibung und ein Kapitel zu Abgrenzung und Modellierung anhand dessen sich eine Zuordnung zu Zielobjekten ermöglichen lässt. Für jeden ausgewählten Baustein muss dokumentiert werden, welchen Zielobjekten er zugewiesen wurde. Einem Zielobjekt können auch mehrere Bausteine zugewiesen sein. Das ist zum Beispiel bei Virtualisierungsservern der Fall, bei denen der Baustein für Virtualisierung, ein Baustein für das entsprechende Betriebssystem und der Baustein für Allgemeine Server gleichermaßen verknüpft werden müssen.

Es gibt diverse Bausteine, die sich nur dem Informationsverbund und keinem konkreteren Zielobjekt zuweisen lassen. Diese müssen für den Informationsverbund einmal ausgewählt und bearbeitet werden. In Kapitel 1.3 Abgrenzung und Modellierung der entsprechenden Bausteine steht dann: „Der Baustein ... ist für den Informationsverbund einmal anzuwenden.“ (5). Wenn es in der Organisation, in der der Informationsverbund zum Thema Onlinewahl definiert wurde, bereits einen übergeordneten Informationsverbund (z.B. für die Organisation) gibt, für den diese Bausteine bereits bearbeitet wurden, kann für diese Bausteine und die damit verbundenen Maßnahmen auf das entsprechende IT-Sicherheitskonzept verwiesen werden. Ein solcher Baustein ist z.B. ISMS.1 Sicherheitsmanagement.

⁷ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

Bausteine, die weder dem Informationsverbund noch einem der in der Strukturanalyse ermittelten Zielobjekte zugeordnet werden können, müssen nicht zur Bearbeitung herangezogen werden.

Die Anforderungen der Bausteine sind unterteilt in die Kategorien Basis-Anforderungen, Standard-Anforderungen und Anforderungen bei erhöhtem Schutzbedarf. Die Aufteilung trägt zum einen den unterschiedlichen Methoden zu Basis- und Standard-Absicherung bei der Erstellung eines IT-Sicherheitskonzepts Rechnung, zum anderen dient sie aber auch dazu, eine Abstufung für die Umsetzung der Anforderungen und der daraus resultierenden Maßnahmen vorzugeben. Basis-Anforderungen sind entsprechend vorrangig umzusetzen und bieten meist einen großen Nutzen. Standard-Anforderungen sind nach den Basis-Anforderungen umzusetzen und können ggf. auch, wenn dies sinnvoll erscheint, durch andere geeignete Anforderungen ersetzt werden. Die Anforderungen bei erhöhtem Schutzbedarf sind entsprechend Empfehlungen für zusätzliche Absicherungen bei einem Schutzbedarf höher als „normal“. Anforderungen sind auf Besonderheiten der Organisation bzw. des Informationsverbunds anzupassen. Bei der Anpassung der Anforderungen ist darauf zu achten, dass diese in Bezug auf ihre Wirksamkeit, Eignung, Praktikabilität, Akzeptanz und Wirtschaftlichkeit angemessen sind.

Bei der Modellierung müssen auch Schnittstellen und betriebliche Dienstleistungsverhältnisse eines Informationsverbunds betrachtet werden. Der Baustein OPS.2.1 Outsourcing für Kunden wird genutzt, wenn betriebliche Dienstleistungen outgesourced werden und Baustein OPS.2.2 Cloud-Nutzung wird für die Nutzung von Dienstleistungen aus einer Cloud genutzt. Je Dienstleistungsverhältnis muss der passende Baustein jeweils einmal angewendet werden.

Auf der BSI-Webseite⁸ stehen Muster für eine exemplarische Modellierung im Bereich Onlinewahlen zur Verfügung.

Auswahl geeigneter Bausteine für eine Onlinewahl

Die Auswahl der Bausteine bei einer Modellierung ist bezüglich der meisten Bestandteile des Informationsverbunds relativ naheliegend. Viele Bausteine werden einmal auf den gesamten Informationsverbund angewendet. Andere werden zu den betroffenen Zielobjekten zugeordnet und für jedes Zielobjekt bzw. jede Gruppe von Zielobjekten angewendet. Bei komplexeren Zielobjekten kann sich die Zuordnung des richtigen Bausteins schwieriger gestalten, weil der Grundschutz ggf. keinen Baustein beinhaltet, der auf das Zielobjekt zugeschnitten ist und dieses vollständig abbildet.

Onlinewahlen sind ein besonderes Einsatzszenario, bei dem besondere gesetzliche Vorgaben zum Tragen kommen können, besondere Prozesse und Anforderungen abgebildet werden müssen und für das es spezielle Gefährdungen und Schadensszenarien gibt. Im IT-Grundschutz gibt es für die Modellierung von Anwendungen einige allgemeinere Bausteine, von denen „APP.3.1 Webanwendungen“ und „APP.6 Allgemeine Software“ die einzigen sind, die für Onlinewahlen herangezogen werden könnten, wobei APP.3.1 auch nur dann Sinn ergibt, wenn es sich bei dem eingesetzten Onlinewahl-Produkt tatsächlich um eine Webanwendung im Sinne des Bausteins handelt.

Die zur Verfügung stehenden Bausteine sind nur bedingt für eine Modellierung von Onlinewahlen geeignet und betrachten nicht alle möglicherweise relevanten Anwendungsfälle und Gefährdungen. Um mit dieser Problematik umzugehen, sieht der IT-Grundschutz vor, für das betroffene Zielobjekt, also die Anwendung Onlinewahl, eine Risikoanalyse vorzunehmen, da es nicht hinreichend durch die Bausteine aus dem IT-Grundschutz abgebildet werden kann.

Bei der Modellierung der Anwendung zur Onlinewahl kann man die vorhandenen Bausteine passend heranziehen. Für die Anwendung zur Onlinewahl ist das auf jeden Fall „APP.6 Allgemeine Software“ und ggf. „APP.3.1 Webanwendungen“. Bei einer Eigenentwicklung müssten noch weitere Bausteine herangezogen werden (siehe unten). Es gibt allerdings auch noch die Möglichkeit für eine Anwendung, für die kein passender Baustein im IT-Grundschutz existiert, einen eigenen benutzerdefinierten Baustein zu

⁸ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

erstellen. Da mit der Erstellung eines benutzerdefinierten Bausteins ein gewisser Aufwand verbunden ist, sollte erwogen werden, ob der Baustein wiederholt Anwendung findet. Bei einem einmaligen oder seltenen Anwendungsfall lohnt sich die Erstellung eines eigenen benutzerdefinierten Bausteins ggf. nicht. Es gibt die Möglichkeit, sich bei der Erstellung Benutzerdefinierter Bausteine mit dem IT-Grundschutz-Referat im BSI abzustimmen. Eine Vorlage, Umsetzungshinweise und weitere Informationen zu benutzerdefinierten Bausteinen gibt es auf der BSI-Webseite⁹.

Die Maßnahmen dieser TR dienen zur Absicherung von Onlinewahlen im Allgemeinen und sind eine gute Grundlage für Maßnahmen im Rahmen der Erstellung eines eigenen Bausteins oder der Risikoanalyse. Sie sind nicht als abschließend zu betrachten und es müssen weitere passende Maßnahmen für die gefundenen Gefährdungen gesucht und evaluiert werden. Dies ist insbesondere wichtig, da jedes Einsatzszenario, jede Betriebsumgebung und jede Anwendung sich voneinander unterscheidet und bei der Risikoanalyse diesen Unterschieden und den dadurch entstehenden unterschiedlichen Anforderungen Rechnung getragen werden muss.

Anforderungen an die Entwicklung von Anwendungen

Ziel der Bausteine CON.8 Software-Entwicklung, CON.10 Entwicklung von Webanwendungen und APP.7 Entwicklung von Individualsoftware ist es allgemeine und anwendungsbezogene Sicherheitsaspekte bei der Planung, Konzeption und Entwicklung von Software zu berücksichtigen. Diese sind natürlich auch für Software relevant, die nicht selbst entwickelt, sondern eingekauft wird. Das Schutzprofil (2) dient dem Zweck entsprechende Vorgaben an eine Zertifizierung zu definieren, die die Ziele dieser Bausteine und noch konkretere Maßnahmen für Onlinewahlen gewährleisten kann.

5.1.1.5 IT-Grundschutz-Check

Beim IT-Grundschutz-Check geht es darum, zu prüfen ob die Maßnahmen aus den in der Modellierung herangezogenen Bausteinen umgesetzt sind, sowie den Zustand und falls notwendig eine entsprechende Begründung zu jeder Maßnahme zu dokumentieren. Der Umsetzungszustand wird im IT-Grundschutz üblicherweise mit Ja, Nein oder teilweise angegeben. Ist eine Maßnahme in einem herangezogenen Baustein aus bestimmten Gründen nicht umsetzbar, kann diese Maßnahme mit einer entsprechenden Begründung auch als entbehrlich gekennzeichnet werden, es sei denn es handelt sich um eine Basis-Anforderung. Die Umsetzung von nicht oder nur teilweise umgesetzten Maßnahmen muss dann nach Konsolidierung mit den Ergebnissen aus der Risikoanalyse im Rahmen einer Realisierungsplanung geplant werden.

Ist ein Baustein mehreren Zielobjekten zugewiesen, die nicht Teil einer Gruppe sind, so muss der Baustein für jedes der Zielobjekte bearbeitet und der Umsetzungsstatus von Maßnahmen separat geprüft werden.

Für den IT-Grundschutz-Check müssen die Informationen aus verschiedenen Bereichen mit unterschiedlichen Ansprechpartnern im Rahmen von Befragungen/Interviews zusammengetragen werden. Um das Ganze effizient zu gestalten, ist es deswegen angeraten die Fragen zur Umsetzung von Maßnahmen aus den Bausteinen durchzugehen und entsprechend zu strukturieren und zuständige Ansprechpersonen für alle zu identifizieren. Für jede Maßnahme muss dann der Umsetzungsstatus und bei nicht oder teilweiser Umsetzung eine entsprechende Begründung eingetragen werden. Dies muss für alle Maßnahmen aus den herangezogenen Bausteinen durchgeführt werden.

Auf der BSI-Webseite¹⁰ stehen Muster für einen exemplarischen IT-Grundschutz-Check im Bereich Onlinewahlen zur Verfügung.

⁹ https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompodium/IT-Grundschutz-Bausteine/Bausteine_Download_Edition_node.html

¹⁰ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

5.1.1.6 Risikoanalyse

Für die Analyse von Risiken müssen innerhalb der Organisation Vorbereitungen getroffen werden. Es gilt dabei zu definieren wie die Verantwortlichkeiten sind, wie die Methodik aus dem IT-Grundschutz auf die Bedürfnisse der Organisation angepasst werden kann und vor allem, wie Risiken zu bewerten sind und wie Risikobereitschaft und Risikoakzeptanz der Organisation sind. Wie schätzt man innerhalb der Organisation Risiken ein, wie bewertet man sie, wie behandelt man sie und unter welchen Bedingungen ist man bereit ein Risiko oder Restrisiko zu akzeptieren? Das ist besonders wichtig für die Einschätzung und Bewertung, sowie für die Behandlung von Risiken.

Die Einschätzung der Risiken sollte sinnvollerweise unter Einbeziehung von geeignetem Fachpersonal vorgenommen werden.

Eine Risikoanalyse muss durchgeführt werden, wenn es Zielobjekte mit einem „hohen“ oder „sehr hohen“ Schutzbedarf gibt, wenn Zielobjekte nicht hinreichend durch die Bausteine aus dem IT-Grundschutz abgebildet werden können oder Zielobjekte in Einsatzszenarien betrieben werden, die der IT-Grundschutz nicht abdeckt. Bei einem „normalen“ Schutzbedarf kann ansonsten davon ausgegangen werden, dass die Bausteine und Maßnahmen aus dem IT-Grundschutz zur Absicherung der Zielobjekte ausreichen.

Wurde für Zielobjekte festgestellt, dass eine Risikoanalyse vorgenommen werden muss, so muss für jedes Zielobjekt ermittelt werden, welchen Gefährdungen es unterliegt. Im IT-Grundschutz-Kompendium (5) gibt es eine Liste aller elementaren Gefährdungen. Außerdem gibt es zu jedem Baustein eine Liste zusätzlicher bausteinspezifischer Gefährdungen und eine Liste zuzuordnender Gefährdungen. Hier sollte geprüft werden, ob weitere elementare Gefährdungen relevant sind. Existiert kein Baustein zu einem Zielobjekt muss die Zuordnung für jede elementare Gefährdung geprüft werden.

In einem weiteren Schritt sollten zusätzliche relevante Gefährdungen für die Zielobjekte ermittelt werden, dabei sollten besonders die Schutzziele betrachtet werden, die einen Schutzbedarf „hoch“ oder „sehr hoch“ aufweisen. Dieses Vorgehen ist besonders wichtig, wenn kein geeigneter Baustein für ein Zielobjekt existiert. In BSI-Standard 200-3 (12) Kapitel 9.3 gibt es Fragestellungen, die beim Finden zusätzlicher Gefährdungen helfen sollen.

Risikoeinschätzung und -bewertung

Zur Einschätzung eines Risikos wird dieses im IT-Grundschutz anhand der Schadenshöhe und Eintrittshäufigkeit bewertet. Für diese sind jeweils vier Kategorien definiert. Für die Eintrittshäufigkeit sind dies selten, mittel, häufig und sehr häufig und für die Schadenshöhe vernachlässigbar, begrenzt, beträchtlich und existenzbedrohend.

Mit der hier abgebildeten Risikomatrix aus dem IT-Grundschutz ist es dann möglich, eine grobe Bewertung der Risiken vorzunehmen. Auch die Risikomatrix und ihre Kategorien gering, mittel, hoch und sehr hoch sollten auf den Kontext der Organisation angepasst werden.

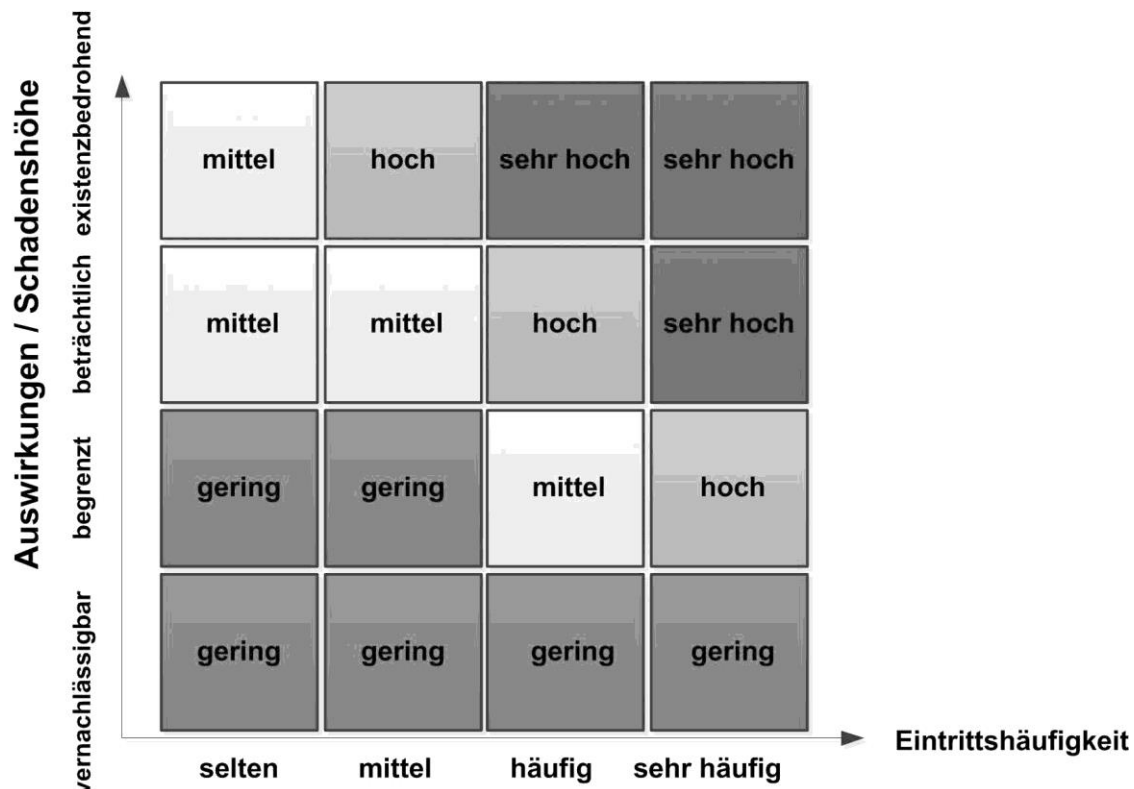


Abbildung 3: Einstufungsmatrix

Auf der BSI-Webseite¹¹ stehen Muster zur Definition der Kategorien für die Risikoeinschätzung und die Risikobehandlung im Bereich Onlinewahlen zur Verfügung.

Risikobehandlung

Es gibt vier grundsätzliche Möglichkeiten der Risikobehandlung. Risiken können vermieden, reduziert, transferiert oder akzeptiert werden. Die Vermeidung eines Risikos ist möglich, wenn zum Beispiel eine andere ggf. weniger risikobehaftete Methode gewählt wird. Durch entsprechende Maßnahmen kann ein Risiko reduziert werden, so dass zum Beispiel die Eintrittshäufigkeit seltener oder die Schadenshöhe geringer ausfällt. Dass nach den getroffenen Maßnahmen verbleibende Restrisiko muss dann weiter behandelt werden. Beim Risikotransfer wird ein Risiko in vertraglichem Rahmen auf eine dritte Partei übertragen (z.B. Versicherung). Risiken, die weder vermieden noch weiter reduziert noch transferiert werden können, müssen akzeptiert werden. Wichtig bei der Behandlung eines jeden Risikos ist es, die Entscheidung über den Umgang mit dem Risiko zu dokumentieren. Das Ziel der Risikobehandlung ist es, dass Risiko so weit zu verringern, dass das Restrisiko durch die Organisation, vertreten durch die jeweilige Leitung, akzeptiert werden kann.

Welcher Umgang mit einem Risiko gewählt wird, obliegt der Organisation, die das Risiko trägt. Ob ein Risiko vermieden, reduziert oder transferiert werden kann, hängt meistens an der Art des Risikos und den zu Grunde liegenden Möglichkeiten. Entsprechend ist es wichtig, dass durch die Organisation definiert ist, unter welchen Bedingungen ein Risiko akzeptiert werden kann, damit hier keine unnötig hohen Risiken bestehen bleiben oder durch unnötige Risikoreduktion unverhältnismäßige Kosten und Aufwände

¹¹ https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

entstehen. Letztendlich bleibt es bei der Risikoakzeptanz aber bei einer Entscheidung, die nur entsprechend des jeweiligen Risikos und der äußeren Einflussfaktoren getroffen werden kann.

Idealerweise werden nur Risiken der Kategorie „gering“ akzeptiert. Es kann vorkommen, dass gewichtigere Risiken akzeptiert werden müssen, da keine aktuelle Möglichkeit zur Vermeidung, Reduktion oder zum Transfer des spezifischen Risikos existiert. Es sollten in diesem Fall Strategien erarbeitet werden, wie im Bedarfsfall mit dem konkreten Risiko umgegangen werden kann.

Auf der BSI-Webseite¹² stehen Muster zur Risikoanalyse im Bereich Onlinewahlen zur Verfügung.

5.1.1.7 Konsolidierung des IT-Sicherheitskonzepts

Ist die Risikoanalyse abgeschlossen und wurden die zusätzlichen Maßnahmen identifiziert, müssen die Ergebnisse der Risikoanalyse mit den Ergebnissen aus der Modellierung konsolidiert werden. Neben zusätzlichen Maßnahmen aus der Risikoanalyse können auch weitere Maßnahmen z.B. aus den Penetrationstests, Technischen Richtlinien und Mindeststandards des BSI oder der Notfallplanung dazukommen. Dabei gilt es zu beachten, dass die neuen Maßnahmen geeignet sind, um den identifizierten Gefährdungen entgegenzuwirken, die neuen Maßnahmen mit denen aus der Modellierung wirksam zusammenwirken, die Maßnahmen sich hinsichtlich Benutzerfreundlichkeit eignen, um auch Akzeptanz und Bedienbarkeit gewährleisten zu können, die Maßnahmen angemessen für die Gefährdungen sind und keine Widersprüche zwischen verschiedenen Maßnahmen auftreten. Stellt man bei der Zusammenführung der Maßnahmen fest, dass Maßnahmen ungeeignet, widersprüchlich oder unwirtschaftlich sind oder von Benutzern nicht akzeptiert werden, sollten die entsprechenden Maßnahmen nochmal überdacht und ggf. überarbeitet oder verworfen werden. Dies gilt insbesondere auch bei der regelmäßigen Prüfung der Wirksamkeit und Überarbeitung von Maßnahmen.

Nachdem die Inhalte aus der Risikoanalyse mit den Ergebnissen aus Modellierung und IT-Grundschutz-Check abgeglichen und in das IT-Sicherheitskonzept integriert wurden, müssen neue Maßnahmen, die im Rahmen der Risikoanalyse hinzugekommen sind wie in Kapitel 0 geprüft werden.

Wenn Integration und IT-Grundschutz-Check der Risikoanalyse abgeschlossen sind, muss die Umsetzung aller nicht umgesetzter oder nur teilweise umgesetzter Maßnahmen geplant werden. Alle Maßnahmen sollten entsprechend einer sinnvollen Umsetzung konkretisiert und ausreichend dokumentiert werden. Für die Umsetzung sollten die Maßnahmen priorisiert werden. Dabei sollten generell zuerst Maßnahmen aus den Basis-Anforderungen, dann Maßnahmen aus den Standard-Anforderungen und dann Maßnahmen für erhöhten Schutzbedarf umgesetzt werden. Für jede Maßnahme sollte die Zuständigkeit geklärt, sowie Kosten und Aufwand geschätzt werden.

Im Rahmen eines ISMS müssen auch entsprechende Prozesse etabliert werden, die einen Rückfluss von Informationen zur für Informationssicherheit verantwortlichen Stelle ermöglichen, damit die notwendige Anpassung und Aktualität der IT-Sicherheitskonzeption gewährleistet ist.

Das IT-Sicherheitskonzept und alle damit verbundenen Anforderungen, Maßnahmen und alle Sicherheitsprozesse und Dokumentationen müssen regelmäßig geprüft und ggf. erweitert oder verbessert werden. Dabei gilt es neben der Aktualität auch die Wirksamkeit zu bewerten und kontinuierlich Verbesserungen durchzuführen. Die Wirksamkeit kann zum Beispiel durch die Auswertung von Kennzahlen oder Sicherheitsvorfällen, die Durchführung von Tests bzw. Simulationen zu getroffenen Maßnahmen oder Audits geprüft werden.

Zertifizierung nach ISO 27001 auf Basis von IT-Grundschutz

Wenn man BSI IT-Grundschutz in der Kern- oder Standard-Absicherung umgesetzt hat, besteht die Möglichkeit sich zertifizieren zu lassen. Dafür gibt es die Zertifizierung nach ISO 27001 auf Basis von IT-Grundschutz (BSI ISO 27001) (23). Im Rahmen der Zertifizierung wird ein Audit durch einen zertifizierten

¹² https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/online-wahlen_node.html

Auditor vorgenommen, auf dessen Basis dann über die Zertifizierung entschieden wird. Das Zertifikat dient als Nachweis der Umsetzung von ISO 27001 und BSI IT-Grundschutz in einem Informationsverbund. Wir empfehlen grundsätzlich eine Zertifizierung nach ISO 27001 auf Basis von IT-Grundschutz für den Informationsverbund. Eine Zertifizierung ist drei Jahre gültig und wird durch jährliche Überwachungsaudits geprüft. Bei größeren Veränderungen im Informationsverbund kann eine Re-Zertifizierung notwendig werden. Eine Re-Zertifizierung wird auch dann notwendig, wenn ein Zertifikat nach Ablauf der dreijährigen Gültigkeitsdauer erneuert werden soll (BSI - Zertifizierungsschema) (31).

5.1.2 Notfallmanagement

Zur Umsetzung eines Notfallmanagements gibt es den BSI Standard 200-4 (22). Für die Modellierung im Rahmen des IT-Sicherheitskonzepts gibt es den Baustein DER.4 Notfallmanagement (5). Im aktuellen Sprachgebrauch wird das Notfallmanagement auch als Business Continuity Management oder kurz BCM bezeichnet.

Beim Notfallmanagement geht es darum die kritischen Geschäftsprozesse durch den Notfallmanagement-Prozess zu schützen. Eine Voraussetzung dafür ist die Identifizierung der kritischen Geschäftsprozesse für einen festgelegten Geltungsbereich. Im Zusammenhang dieser technischen Richtlinie zum Thema Onlinewahlen wurde bereits für die Umsetzung von BSI IT-Grundschutz auf die Formulierung eines Geltungsbereichs im Sinne des Informationsverbunds eingegangen. Dieser Geltungsbereich sollte für das Notfallmanagement übernommen werden. Wurde in einer Organisation ein Notfallmanagement etabliert muss dieses um die kritischen Geschäftsprozesse der Onlinewahl erweitert werden.

Das BSI bietet für die Umsetzung des Standard 200-4 umfangreiche Hilfsmittel mit vielen Dokumenten und Hilfestellungen¹³.

Für das Notfallmanagement einer jeden Organisation müssen Ziele und Strategie festgelegt werden. Dazu gehört eine Abgrenzung des Notfallmanagements von anderen Themenbereichen wie z.B. dem Risikomanagement oder dem IT-Sicherheitsmanagement, Festlegungen zu schützender Geschäftsziele und was im Rahmen der Geschäftsprozesse als existentielle Bedrohung betrachtet wird, sowie Maßnahmen im Rahmen einer Notfallbehandlung.

Wie bei einem ISMS ist auch im Notfallmanagement die Verantwortung durch die Leitung ein wesentlicher Faktor. Es muss eine entsprechende Leitlinie für das Notfallmanagement erstellt werden. Außerdem müssen für den Notfallmanagement-Prozess die Rollen und Zuständigkeiten definiert sein, damit im Notfall alle Handlungsmöglichkeiten und -Befugnisse gegeben sind. Dazu gehört die Einrichtung eines Notfallbeauftragten, eines Krisenentscheidungsorgans für den strategischen Bereich, eines Krisenstabs für die Planung und Steuerung im Rahmen eines Notfalls und von Notfallteams für die operative Notfallbewältigung. Bei der Besetzung sollten die besonderen Anforderungen bezüglich der Behandlung von Notfällen berücksichtigt und das Personal geeignet ausgewählt werden.

Ausgelagerte Geschäftsprozesse müssen bei der Konzeption des Notfallmanagements beachtet werden. Insbesondere durch die Business Impact Analyse und die Risikoanalyse gewinnt man hierbei wichtige Informationen über die Geschäftsprozesse, die bei der Vertragsgestaltung mit dem Dienstleister oder bei der Betrachtung eines Outsourcing-Vorhabens berücksichtigt werden müssen. Beispiele für zu treffende Vereinbarungen sind z.B.: Berichtspflichten des Dienstleisters, Reaktions- und Erreichbarkeitszeiten ggf. bis zu 24/7, Berechtigungen bezüglich der ausgelagerten Prozesse zur Weisung an den Dienstleister, etc.

Business Impact Analyse (BIA) (32)

Die BIA dient dazu, kritische Geschäftsprozesse, also Geschäftsprozesse, die für die Aufrechterhaltung des Kerngeschäfts einer Organisation von besonderer Bedeutung sind, zu identifizieren, die Folgen eines

¹³ https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/BSI-Standard-200-4_Hilfsmittel/BSI_Standard_200_4_Hilfsmittel_node.html

Ausfalls dieser kritischen Geschäftsprozesse abzuschätzen und eine Priorität für deren Wiederanlauf zu ermitteln.

Um eine BIA durchführen zu können, braucht man eine Übersicht über alle relevanten Geschäftsprozesse einer Organisation. Diese sollten für die weitere Analyse unter anderem jeweils einen Prozessverantwortlichen haben, sowie eine Zuordnung zu allen abhängigen Geschäftsprozessen und den mit Ihnen verbundenen Zielen der Organisation. Dies wird für eine Einordnung des Schadens und der Priorität des Wiederanlaufs benötigt.

Eine BIA kann dann in den folgenden Schritten ablaufen:

- Auswahl von Geschäftsprozessen für die BIA
- Schadensanalyse
- Festlegung von Wiederanlaufparametern
- Berücksichtigung von Abhängigkeiten
- Priorisierung und Einschätzung der Kritikalität der Geschäftsprozesse
- Ressourcenerhebung für Normal- und Notfallbetrieb
- Kritikalität und Wiederanlaufzeiten der Ressourcen

Bei der Auswahl der Geschäftsprozesse für die BIA muss mindestens der Geschäftsprozess „Durchführung einer Onlinewahl“, also der Geschäftsprozess, der für die Dauer der Erreichbarkeit des Onlinewahlsystems während des Wahlzeitraums relevant ist, betrachtet werden.

Für die Schadensanalyse kann die Einteilung der Schutzbedarfskategorien genutzt werden. Bei den Schadenskategorien kann hier noch die Kategorie niedrig für kaum spürbare Auswirkungen ergänzt werden. Man kann für die Schadenskategorien auch dieselben Schadensszenarien anlegen.

Im Rahmen der Festlegung von Wiederanlaufparametern werden für die Geschäftsprozesse maximal tolerierbare Ausfallzeit, Wiederanlaufzeit und Wiederanlaufniveau festgelegt. Bei der Wiederanlaufzeit handelt es sich um die angestrebte Zeit, in der der Wiederanlaufprozess erfolgt sein soll. Das Wiederanlaufniveau gibt die Kapazität an, mit der ein stabiler Notbetrieb erfolgen kann.

Bei der Berücksichtigung von Abhängigkeiten geht es darum, mögliche Zusammenhänge für den Wiederanlauf eines Geschäftsprozesses zu anderen Prozessen, Geschäftszielen, Ressourcen oder anderer besonderer Ereignisse zu erkennen und einzuplanen.

Die Priorisierung ergibt sich grundsätzlich aus den festgelegten Wiederanlaufzeiten für die Geschäftsprozesse. Wenn ein Prozess schneller wieder angelaufen sein muss, dann ist naheliegend, dass er kritischer bzw. von höherer Priorität ist als ein anderer. Außerdem kann die Kritikalität eines jeden Geschäftsprozesses bewertet werden. Die Kritikalität kann anhand von Kritikalitätskategorien ermittelt werden, die sich z.B. an der Wiederanlaufzeit oder der Schadenshöhe orientieren.

Bei der Ressourcenerhebung wird ermittelt, welcher Bedarf an verschiedenen Ressourcen im Normal- und Notbetrieb für einen Geschäftsprozess erforderlich sind. Es werden folgende Ressourcen unterschieden und ermittelt:

- Personal
- Informationen (digitale und analoge Daten)
- IT (Anwendungen, Systeme und Netze)
- Spezialgeräte oder -anlagen (z.B. Produktionsanlagen oder Sicherheitsschleusen)
- Dienstleistungen
- Infrastruktur (z.B. Gelände, Gebäude und Räume)
- Sonstige Betriebsmittel (Ressourcen die in keine der anderen Kategorien passen)

Die Ressourcenerhebung ist wichtig für eine spätere Notfallvorsorge und Notfallplanung.

Die Kritikalität und Wiederanlaufzeiten der Ressourcen ergeben sich aus Kritikalität und Wiederanlaufzeiten der Geschäftsprozesse und vererben sich entsprechend. Für Ressourcen können allerdings zusätzliche Anlaufzeiten bis zur Bereitstellung einer jeweiligen Ressource notwendig werden. Hierbei ist auch auf Abhängigkeiten der Ressourcen untereinander und verschiedene Zusammenhänge zu mehreren Geschäftsprozessen zu achten. Es kann beispielsweise sein, dass Systeme für einen ordnungsgemäßen Betrieb nur in einer bestimmten Reihenfolge wiederhergestellt werden dürfen.

Risikoanalyse im Rahmen von Notfallmanagement

Die Risikoanalyse im Rahmen des Notfallmanagements kann weitestgehend entfallen, wenn bereits eine Risikoanalyse im Rahmen der Erstellung des IT-Sicherheitskonzeptes durchgeführt wurde. Es sollte allerdings geprüft werden, ob für alle kritischen Geschäftsprozesse, für die eine Risikoanalyse durchgeführt werden sollte, auch wirklich eine erfolgt ist und ob im Rahmen der Risikoanalyse auch Gefährdungen im Sinne des Notfallmanagements betrachtet wurden. Andernfalls müssen diese ergänzt werden.

IST-Stand, Kontinuitätsstrategie und Notfallvorsorgekonzept

Für die Entwicklung eines Notfallvorsorgekonzeptes wird als erstes der IST-Stand an Notfallvorsorgemaßnahmen aufgenommen. Damit können mögliche Strategieoptionen auf Basis bereits getroffener Maßnahmen besser abgeschätzt und ausgewählt werden und die noch umzusetzenden Maßnahmen können mit einem Soll-Ist-Vergleich ermittelt werden.

Bei der Auswahl der Strategieoptionen für die Kontinuitätsstrategie spielen dann die in der BIA ermittelten Wiederanlaufzeiten und die für entsprechende Maßnahmen anfallenden Kosten eine Rolle. Zusätzlich müssen entsprechende Vorgaben (z.B. hausinterne Regelungen, Regelungen aus dem IT-Grundschutz etc.) beachtet werden. Die verschiedenen Strategieoptionen (z.B. minimale bis große Lösung) werden in Kontext gesetzt zu genannten Faktoren und dem zu erwartenden Restrisiko. In Bezug auf die zu betrachtenden Ressourcen eines jeden Prozesses müssen Maßnahmen zu den Strategieoptionen existieren und die geeignete Option muss ausgewählt werden. Auf der Webseite des BSI zu den Hilfsmitteln für BSI-Standard 200-4 gibt es Beispiele dafür, wie Maßnahmen hierzu aussehen können.

Das Notfallvorsorgekonzept beinhaltet alle Informationen des Notfallkontextes, die nicht zur direkten Bewältigung eines Notfalls beitragen. Dies sind insbesondere vorbeugende Maßnahmen und Maßnahmen, die die Handlungsfähigkeit im Rahmen eines Notfalls ermöglichen oder verbessern. Alles was die direkte Bewältigung eines Notfalls betrifft, wird im Notfallhandbuch beschrieben. Auf Maßnahmen aus dem IT-Sicherheitskonzept, die für die Notfallvorsorge relevant sind sollte im Notfallvorsorgekonzept referenziert werden. Wie auch beim IT-Sicherheitskonzept müssen die Maßnahmen aus dem Notfallvorsorgekonzept geplant und umgesetzt werden.

Notfallbewältigung

Durch geeignete Maßnahmen kann das Risiko für die Geschäftsprozesse meistens nicht vollständig vermieden werden. Um mit dem verbleibenden Restrisiko umzugehen, muss für einen entsprechenden Notfall vorgesorgt werden. Im Folgenden die wesentlichen Punkte zum Ablauf der Notfallbewältigung, wobei die Zuständigkeit für die Behebung des Notfalls vom Krisenstabsleiter in Abhängigkeit zur Schwere des Notfalls gewählt werden kann:

- Sofortmaßnahmen
- Alarmierung, Eskalation und Entscheidung (Fachabteilung < Notfallteams < Krisenstab)
- Arbeit des Krisenstabs: Lagefeststellung, Lagebeurteilung, Handlungsoptionen und Maßnahmen festlegen, Durchführung und Kontrolle
- Bei Behebung des Notfalls oder der Krise: Deeskalation
- Nacharbeiten

Sind die Sofortmaßnahmen bereits erfolgreich, dann muss der restliche Notfallbewältigungsprozess nicht mehr durchlaufen werden. Die Arbeit des Krisenstabs während der Notfallbewältigung muss revisionssicher

in einem Einsatztagebuch dokumentiert werden. Dies erleichtert die Lagebeurteilung sowie die Nachbereitung des Notfalls im Rahmen der Verbesserung des Prozesses.

Notfallhandbuch

Das Notfallhandbuch beinhaltet die für die Bewältigung von Notfällen wesentlichen Informationen. Es kann aus einem oder mehreren Dokumenten bestehen und hat zum Ziel als Hilfestellung bei der Bewältigung von Notfällen zu dienen. Im Wesentlichen geht es beim Notfallhandbuch um die folgenden Inhalte:

- Sofortmaßnahmenplan
- Krisenstabsleitfaden (Ziele, Grundsätze und Rahmenbedingungen für das strategische Handeln in einer Krise)
- Krisenkommunikationsplan (Interne und externe Kommunikation in einer Krise)
- Geschäftsfortführungspläne (Pläne zur Fortführung kritischer Geschäftsprozesse)
- Wiederanlaufpläne (Wiederherstellung von Ressourcen)

Tests und Übungen

Test und Übungen dienen der Überprüfung von Funktionsfähigkeit von Maßnahmen und Notfallmanagement. Sie sorgen außerdem dafür, dass durch die Erprobung der Notfallvorsorge und der Notfallbewältigung im Ernstfall ein reibungsloserer Ablauf gewährleistet werden kann. Deswegen ist es wichtig entsprechende Tests und Übungen zu planen und durchzuführen und im Nachgang Verbesserungen in Bezug auf bei der Durchführung aufgefallene Schwierigkeiten vorzunehmen. Hierzu gibt es verschiedene Arten von Tests und Übungen:

- Test der technischen Vorsorgemaßnahmen (Tests der Funktionsfähigkeit und Angemessenheit von Notfallvorsorge-Maßnahmen)
- Funktionstest (Test von Abläufen und zusammenhängen Systemen (z.B. Wiederanlaufpläne, Sofortmaßnahmen, etc.))
- Plan-Review (Plausibilitätsprüfung aufgestellter Notfallbewältigungspläne)
- Planbesprechung (Gedankliches Durchspielen von z.B. Notfallszenarien zur Validierung von Plänen)
- Stabsübungen (Planbesprechungen im Rahmen des Krisenstabs, Prüfung der Zusammenarbeit)
- Stabsrahmenübungen (Planbesprechung zur Prüfung der Zusammenarbeit zwischen Krisenstab und operativen Notfallteams)
- Kommunikations- und Alarmierungsübung (Tests von Melde- und Eskalationswegen)
- Simulation von Szenarien (Umfangreicher Test zur Bewältigung von Notfällen über die einzelnen Schritte des Notfallmanagementprozesses)
- Ernstfall- oder Vollübung (Vollständiger Test des Notfallmanagements unter Einbeziehung aller möglichen ggf. auch externen Beteiligten)

Die Tests und Übungen müssen entsprechend geplant und vorbereitet werden. Dafür sollten entsprechende Tests und Übungsdokumentationen, Plan aller Tests und Übungen insgesamt (generelle Vorgaben und zeitliche Planung), sowie jeweils: eine Konzeption, ein Protokoll und bei umfangreichen Tests und Übungen ein detaillierter Durchführungsplan) erstellt werden, die die wesentlichsten Informationen zu den Tests und Übungen beinhalten. Dazu gehören z.B. Informationen zu Umfang und Häufigkeit der Tests, Zuständigkeiten für die Tests und Übungen, Inhalt der Tests und Übungen (Was wird getestet?), Art der Dokumentation der Test- und Übungsergebnisse, Auswertung der Tests und Übungen, etc. Es sollten für alle Bereiche des Notfallmanagements Tests geplant werden. Die Tests sollten regelmäßig wiederholt werden. Je nach Umfang des Tests oder der Übung jährlich oder alle 2-3 Jahre. Entsprechende gesetzliche Vorgaben, die für eine Organisation dazu existieren müssen beachtet werden.

Regelmäßige Kontrolle und Aktualisierung

Notfallvorsorgemaßnahmen und Notfallmanagement müssen regelmäßig auf ihre Wirksamkeit und Aktualität untersucht und ggf. angepasst werden, damit im Bedarfsfall eine funktionsfähige Notfallbewältigung vorgenommen werden kann. Werden Mängel oder Verbesserungspotential festgestellt,

müssen die Maßnahmen oder Prozesse dahingehend angepasst werden. Für die Aufrechterhaltung eines funktionsfähigen Notfallmanagements ist es unerlässlich, dass entsprechende Ergebnisse aus Tests, Übungen und Notfällen dokumentiert und ausgewertet werden.

6 Anhang 2: Durchführung einer hybriden Wahl

6.1 Einführung in hybride Wahlen

Von hybriden Wahlen gemäß dieses Handlungsleitfadens spricht man, wenn verschiedene Entscheidungsmechanismen kombiniert werden können. Zum Beispiel wenn die Wahl sowohl als Onlinewahl, als auch als Briefwahl und /oder Präsenzwahl ermöglicht wird.

Bei der Onlinewahl werden die abgegebenen Stimmen über das Internet oder Intranet übermittelt und elektronisch ausgezählt. Zur Stimmabgabe für die Onlinewahl wird dabei meistens ein handelsübliches elektronisches Gerät verwendet, also z.B. ein PC, ein Smartphone oder ein Tablet. Wahlmaschinen, die im Wahllokal lediglich den Stimmzettel ersetzen, fallen nicht unter Onlinewahlen.

Bei der Briefwahl werden die Wahlunterlagen an den Wählenden per Post gesandt und dann können die ausgefüllten Wahlunterlagen zurückgeschickt werden.

Bei der Wahl in Präsenz können die Wählenden ihre Stimmzettel direkt in die Wahlurne im Wahllokal abgeben.

Hybride Wahlen und Abstimmungen können in vielen verschiedenen Bereichen eingesetzt werden (z.B. eine Wahl zur Gleichstellungsbeauftragten, Wahl des Betriebsrates usw.). Genauso vielfältig wie die Einsatzszenarien sind auch die technischen Sicherheitsmaßnahmen bei der Abstimmung, die Anforderungen an die Geheimhaltung der einzelnen Stimmen sowie die Transparenz bei der Ergebnisermittlung. So wird beispielsweise für die Wahl des Vorstands eines Freizeit-Sportvereins häufig ein Onlinewahl- oder -Abstimmungssystem ausreichen, bei dem die Stimmen nur transportverschlüsselt (nicht Ende-zu-Ende-verschlüsselt) übertragen werden, da die Manipulationsgefahr und Tragweite der Wahl relativ gering ist. Bei Wahlen von Betriebsräten oder gar politischen Wahlen muss die Wahl dagegen viel höheren Ansprüchen und rechtlichen Vorgaben genügen.

Für Briefwahlen und Präsenzwahlen ist mit einem höheren organisatorischen Aufwand zu rechnen als nur für Onlinewahlen allein, da die Stimmzettel gedruckt werden müssen und für die Briefwahl die Wahlunterlagen zusätzlich versendet werden müssen.

Es gibt verschiedene Möglichkeiten hybride Wahlen umzusetzen. Daher kann es sein, dass weitere Herausforderungen auftreten. Deshalb kann diese Auflistung nicht als vollständig bezeichnet werden.

Onlinewahl: Die Wählenden geben ihre Stimme über ihr Smartphone oder einen Computer ab. Die Stimmen werden über das Internet oder Intranet an die Wahlsoftware übertragen, die das Wahlergebnis ermittelt.

Briefwahl: Die Wählenden geben ihre Stimmzettel in einem verschlossenen Stimmzettelumschlag. Dieser wird zusätzlich in einen Rückumschlag gegeben, der den Wahlschein des Wählenden enthält. Der Rückumschlag wird per Post versandt oder kann persönlich im Briefwahlbüro abgegeben werden.

Präsenzwahl: Die Wählenden geben ihren Stimmzettel im Wahllokal direkt in die Wahlurne.

Für weitere Informationen möchten wir auf die geltende Onlinewahlverordnung vom 23. September 2020 (BGBl. I S. 2034) (33), auf die vom BSI veröffentlichte Technische Richtlinie TR-03169 (34) IT-sicherheitstechnische Anforderungen zur Durchführung von nicht-politischen Online-Wahlen und -Abstimmungen und auf die BSI TR-03162 (35) IT-sicherheitstechnische Anforderungen zur Durchführung einer Online-Wahl im Rahmen des Modellprojekts nach § 194a Fünftes Buch Sozialgesetzbuch (Online-Wahl) verweisen.

Da wir unsere technischen Richtlinien ständig aktualisieren, können sich Interessierte mit dem BSI zum Thema Onlinewahlen austauschen. Über dieses Forum informiert das BSI über neue Erkenntnisse oder

Veranstaltungen und steht für Fragen zur Verfügung. Zur Anmeldung für das Austauschforum senden Sie uns eine E-Mail an das Postfach online-wahlen@bsi.bund.de.

6.2 Wahlgrundsätze

Wahlgrundsätze formulieren grundlegende Anforderungen an demokratische Wahlen. Es werden die folgenden Wahlgrundsätze unterschieden: Allgemein, Unmittelbar, Frei, Gleich, Geheim und den Grundsatz der Öffentlichkeit der Wahl.

Bei hybriden Wahlen sind die Wahlgrundsätze bei den verschiedenen Wahlverfahren unterschiedlich ausgeprägt:

Allgemein

Der Wahlgrundsatz der Allgemeinheit fordert, dass bei der Wahl alle Bürgerinnen und Bürger sowohl als Wählender, also auch als Wahlkandidat teilnehmen können. Ein Zugang zur Wahl muss daher unabhängig von Merkmalen wie Geschlecht, Rasse, Vermögen oder Religionszugehörigkeit stets gewährleistet sein. Unabhängig davon kann es Einschränkungen geben, beispielsweise bei einer Vereinswahl, bei der nur Mitglieder wählen dürfen.

Durch die Möglichkeit der Auswahl des Wahlverfahrens für jeden einzelnen Wählenden ist der barrierefreie Zugang gegeben, da jeder selbst entscheiden kann ob die Briefwahl oder die Onlinewahl oder die Wahl in Präsenz für ihn einfacher zu handhaben ist.

Unmittelbar

Dieser Wahlrechtsgrundsatz bedeutet, dass die zu Wählenden durch die Wählenden mittels Direktwahl gewählt werden und insbesondere nicht durch Mittelsmänner wie Wahlmänner.

Die Ausgestaltung als hybride Wahl hat keine Auswirkung auf diesen Wahlgrundsatz.

Frei

Der Grundsatz der Freiheit fordert, dass die Wählenden ihre Wahlentscheidung ohne Zwang oder unzulässige Beeinflussung selbst treffen können.

Bei hybriden Wahlen kann nicht in jedem Fall sichergestellt werden, dass jeder Wählende nicht etwa gezwungen wurde in einer bestimmten Weise zu wählen. Bei Brief- und Onlinewahl kann die Wahlumgebung nicht überprüft werden. Bei der Präsenzwahl ist dieser Grundsatz durch die Wahlkabine und Regeln zu deren Nutzung eher gewährleistet.

Gleich

Nach dem Wahlrechtsgrundsatz der Gleichheit muss jeder Wahlberechtigte die gleiche Stimmenanzahl besitzen und jede abgegebene Stimme muss das gleiche Gewicht bei der Zusammensetzung des Wahlergebnisses haben.

Bei hybriden Wahlen muss gewährleistet werden, dass jeder Wählende nur eine Stimme insgesamt abgeben kann.

Es muss gewährleistet werden, dass alle Wählenden die gleiche Stimmanzahl besitzen.

Es stellt hier eine Herausforderung dar, sicher zu stellen, dass nur einer Wahlmethode der Vorrang zur Stimmabgabe gegeben wird. Dies kann bspw. über den Wahlzeitraum gelöst werden.

Geheim

Dieser Wahlgrundsatz besagt, dass der Wahlvorgang so stattfinden muss, dass die eigene Wahlhandlung nur für die Wählenden selbst nachvollziehbar ist.

Auch dieser Wahlgrundsatz kann eine Herausforderung darstellen, wenn nur ein Wählender z.B. in Präsenz oder per Briefwahl abstimmt und der Rest der Wählenden online. Es könnte der Wahlgrundsatz geheim nicht gewährleistet werden.

Öffentlich

Dieser Wahlrechtsgrundsatz besagt, dass wesentliche Teile der Wahl, wie insbesondere die korrekte Auszählung, durch die Öffentlichkeit überprüfbar sein müssen. Dies kann bei einer hybriden Wahl zu unterschiedlichen Ausprägungen führen:

- Bei Onlinewahlen ist die Ende-zu-Ende-Verschlüsselung umzusetzen damit die eigene Stimmabgabe für den einzelnen Wählenden überprüfbar und das Wahlgeheimnis gewährleistet bleibt.
- Bei der Präsenzwahl kann der Wählende bei der Auszählung anwesend sein.
- Bei der Briefwahl kann eine Anwesenheit bei der Auszählung nicht immer gewährleistet werden.

6.3 Herausforderungen von hybriden Wahlen

Allein die Durchführung einer Wahl, sei es in Präsenz, per Brief oder Online geht mit einigem Aufwand und Herausforderungen einher. Die Organisation und Durchführung einer hybriden Wahl, die zwei oder gar alle drei Wahlarten miteinander kombiniert hat mit zusätzlichen Herausforderungen zu kämpfen. Sie bietet jedoch auch Vorteile, die mit nur einer Wahlform nicht erreicht werden.

Dazu gehört, dass die Wählenden sich die Wahlform aussuchen können, denen sie am ehesten vertrauen und die zu ihnen passt. Zudem ermöglichen hybride Wahlen eine höchstmögliche Barrierefreiheit. Die digitale Barriere durch eine reine Onlinewahl kann bspw. durch eine Teilnahme vor Ort oder per Brief, die Barriere, in einem bestimmten Zeitraum vor Ort abzustimmen, durch eine Teilnahme per Brief oder Online aufgehoben werden. Damit kann sowohl das Vertrauen in die Wahl als auch die Wahlbeteiligung selbst erhöht werden.

Als Herausforderung ist an erster Stelle der hohe organisatorische Aufwand und der hohe Einsatz von Ressourcen zu nennen. Zudem muss sichergestellt werden, dass eine doppelte Stimmabgabe technisch und organisatorisch ausgeschlossen wird. Aufgrund der verschiedenen Wahlformen muss hier zusätzlich eine Regelung getroffen werden, welche Stimme Vorrang hat, wenn bspw. sowohl per Brief als auch online gewählt wird. Eine weitere Herausforderung ist die Wahrung des Wahlgeheimnisses. Wenn es zwei oder drei verschiedene Wahlformen gibt, besteht die Gefahr, dass bspw. bei der Präsenzwahl nur ein oder wenige Wählende teilnehmen und so die Stimme der Person zugeordnet werden können.

Im folgenden Kapitel möchten wir auf diese Herausforderungen eingehen und mögliche Lösungsansätze aufzeigen.

6.4 Durchführung von hybriden Wahlen

6.4.1 Möglicher Ablauf einer hybriden Wahl

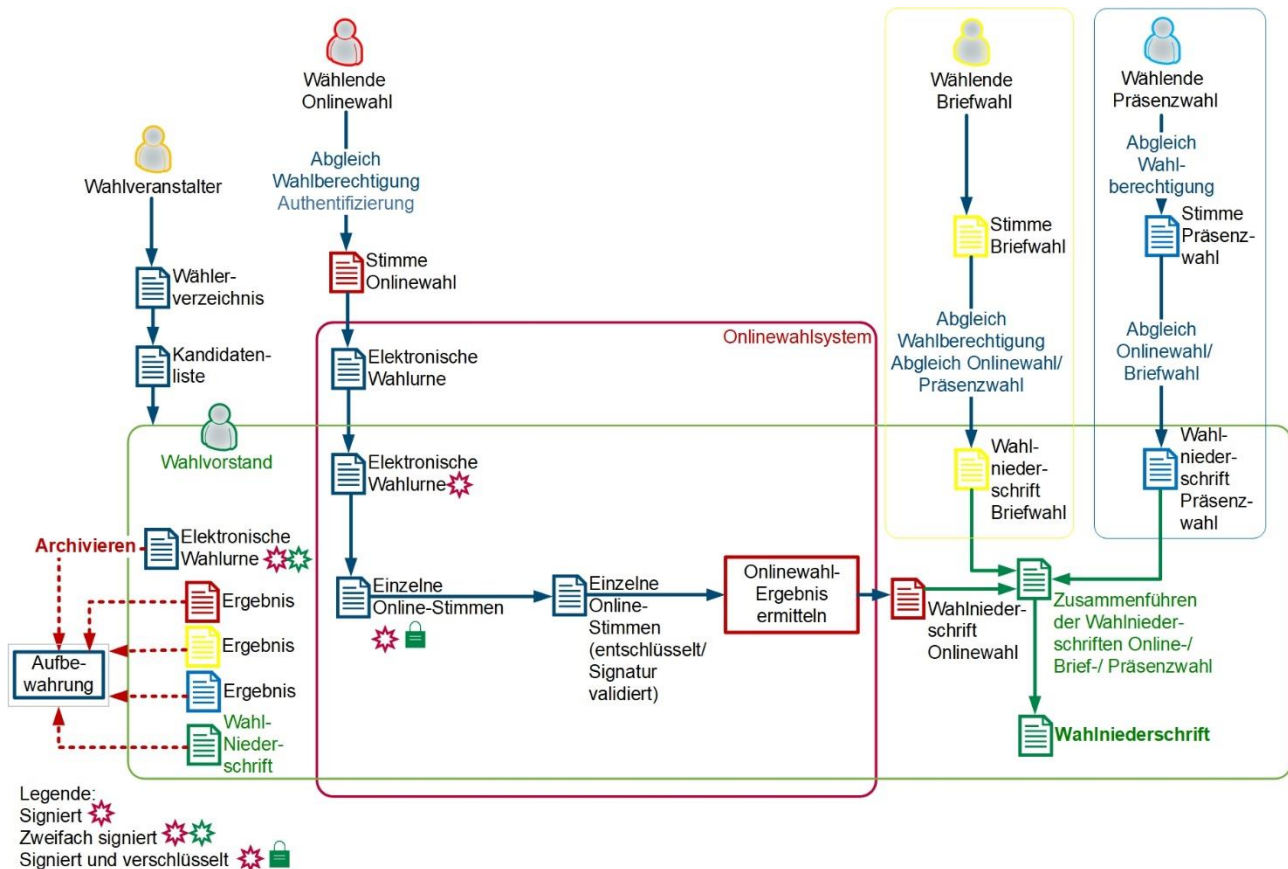


Abbildung 4: Ablaufdiagramm Hybride Wahlen

Die Grafik zeigt den möglichen Ablauf einer hybriden Wahl, bei der Onlinewahl, Briefwahl und Präsenzwahl kombiniert werden können. Sie stellt dar, wie die Stimmen abgegeben, verarbeitet, validiert und schließlich ausgewertet werden können. Hier finden sie eine Beschreibung der Vorgänge:

Der Online-Wählende durchläuft einen Abgleich zur Wahlberechtigung (Identifizierung & Authentifizierung). Danach wird die Online-Stimme abgegeben. Diese gelangt in die elektronische Wahlurne, wird dort signiert. Anschließend werden die Online-Stimmen einzeln signiert und verschlüsselt gespeichert. Sie werden entschlüsselt, die Signatur validiert und das Onlinewahlergebnis kann ermittelt werden. Das Ergebnis fließt in eine Wahlniederschrift zur Onlinewahl.

Alternativ kann der Briefwählende seine Stimme abgeben. Diese wird mit der Online-/Präsenzwahl abgeglichen. Das Ergebnis wird in einer Wahlniederschrift Briefwahl festgehalten.

Alternativ kann der Präsenzwählende seine Stimme vor Ort abgeben. Auch hier erfolgt ein Abgleich (mit den anderen Wahlarten). Das Ergebnis fließt in die Wahlniederschrift Präsenzwahl.

Die Wahlniederschriften aus Online-, Brief- und Präsenzwahl werden zusammengeführt zu einer finalen Wahlniederschrift. Alle Ergebnisse sowie die Urneninhalte werden archiviert und aufbewahrt.

Mehrfach-Signaturen sichern die Integrität. Verschlüsselung stellt Vertraulichkeit sicher. Die Prozesse verlaufen parallel, aber werden zur Ergebnisermittlung vereinheitlicht.

6.4.2 Technische und organisatorische Besonderheiten

Um die in Kapitel [6.2](#) genannten Wahlgrundsätze erfüllen zu können, bedarf es technische und organisatorische Maßnahmen, die zusätzlich ergriffen werden müssen.

Insbesondere kann es, bei komplexeren Systemen auch eher zu Fehlern kommen. Selbst der Einsatz eines nach BSI-CC-PP-0121 (2) zertifizierten Produktes kann Probleme bei den Schnittstellen zu anderen Wahlformen nicht lösen.

6.4.2.1 Mehrfache Stimmabgabe

Eine doppelte oder gar dreifache Stimmabgabe kann möglich sein, wenn eine hybride Wahl durchgeführt wird. Dabei gilt zu beachten, dass alle Wählenden die gleiche Anzahl an Stimmen abgeben dürfen (sofern dies die Wahlverordnung entsprechend vorsieht). Dies bedeutet, dass verhindert werden muss, dass Wählende sowohl bei den einzelnen Wahlformen als auch übergreifend (bspw. per Brief und Online) ihre Stimme abgeben oder Stimmen überschrieben werden dürfen.

Soll verhindert werden, dass Wählende ihre Stimme sowohl per Brief, online und persönlich abgeben, muss die Möglichkeit erwogen werden, die Wahlzeiträume anzupassen. Dabei ist eine Möglichkeit, die Wahl zuerst in Präsenz – bei einer Betriebsratswahl bspw. im Betrieb – stattfinden zu lassen und allen, die nicht gewählt haben, den Zugang zur Onlinewahl zukommen zu lassen.

Zudem bestünde die Möglichkeit, dass die Zugangsdaten zur Onlinewahl auf der Wahlberechtigung freigerubbelt werden muss. Sobald dies erfolgt ist, darf keine Präsenzwahl mehr möglich sein. Hier besteht selbstverständlich das Risiko, dass jemand das Feld freigerubbelt, sich dann aber doch für die Präsenzwahl entschieden hat, ohne online gewählt zu haben.

Eine andere Möglichkeit besteht darin, dass im Falle einer doppelten Stimmabgabe, bspw. einmal per Brief und einmal online, eine Stimme durch die jeweils andere überschrieben wird. Dazu ist es jedoch notwendig, dass die Stimme zugeordnet werden kann. Eine mögliche Umsetzung besteht darin, dass das Onlinewahlssystem zwar keine Zuordnung mehr zwischen den Wählenden und den abgegebenen Stimmen herstellen kann, jedoch ein pseudonymisiertes bzw. anonymisiertes Wählendenverzeichnis führt, aus dem hervorgeht, welche Wählendenkennzeichen ihre Stimme bereits abgegeben haben. Werden zudem Briefwahlstimmen denselben Kennzeichen zugeordnet, werden diese vernichtet und damit den Onlinewahlstimmen den Vorrang gegeben. Diese Vorgehensweise setzt voraus, dass die Briefwahlstimmen erst nach dem Onlinewahlzeitraum ausgezählt werden und dass die Wählendenkennzeichen von den Briefwahlstimmen gelesen werden können, ohne die abgegebene Stimme lesen zu können, bspw. durch einen doppelten Briefumschlag.

Es ist möglich, die Onlinewahlstimme zu überschreiben, wenn das Onlinewahlssystem diese Option bereitstellt. Mit dem sogenannten Revoting werden die Stimmen so gespeichert, dass sie dem Wählendenkennzeichen zugeordnet bleiben und von den Wählenden selbst beliebig überschrieben werden können. Diese Möglichkeit kann den Grundsatz des Wahlheimnisses einschränken.

Ebenfalls ist eine Kombination aus verschiedenen Wahlzeiträumen und der Bevorzugung einer Wahlform möglich.

6.4.2.2 Kompromittierung des Wahlheimnisses

Die Möglichkeit, die Wählenden auf bis zu drei verschiedene Wahlformen zu verteilen, eröffnet die Möglichkeit, dass das Wahlheimnis unbeabsichtigt durch die Wählenden selbst kompromittiert wird. Dies kann geschehen, wenn bspw. die Mehrheit ihre Stimme online abgibt und sich nur eine kleine Handvoll Wählende für die physische Urne entscheiden. Wahlbeobachter und -beobachterinnen und Wahlhelfer und -helferinnen können so möglicherweise Rückschlüsse auf die abgegebenen Stimmen ziehen. Dies lässt sich schwer planen, insbesondere, wenn zum ersten Mal eine hybride Wahl durchgeführt wird und nicht abschätzbar ist, inwiefern welche Wahlformen von den Wählenden wie bevorzugt werden.

6.5 Fazit

Hybride Wahlen können dafür sorgen, alle Wählenden mitzunehmen und durch die verschiedenen Wahlmöglichkeiten die Wahlbeteiligung zu erhöhen. Gleichzeitig bedarf es hier besonderer organisatorischer Maßnahmen, um den Herausforderungen zu begegnen, die sich durch die Komplexität ergeben.

7 Glossar

Business Impact Analyse	Die Business Impact Analyse (BIA) betrachtet kleinste Prozessbestandteile und ihre Abhängigkeiten auf ihre individuellen Auswirkungen auf den Geschäftsprozess hinsichtlich der Verfügbarkeit. Dabei werden Kennzahlen, wie die Wiederherstellungszeit für die einzelnen Prozessbestandteile ermittelt.
Cast-as-Intended	Der Begriff beschreibt den Status, dass durch die Stimmgabe die Intention des Wählenden erfasst wurde.
Cloudlösung	Der Anbieter stellt das Onlinewahlprodukt als Software-as-a-Service zur Verfügung, d. h. der Betrieb des Wahlprodukts wird durch den Anbieter selbst organisiert (in einer eigenen oder einer von einem Dritten gehosteten Cloud).
Counted-as-Recorded	Der Begriff beschreibt den Status, dass die gespeicherte Stimme korrekt in das Wahlergebnis einbezogen wurde.
elektronische Wahlurne	Die elektronische Wahlurne ist ein digitales Medium zur elektronischen Speicherung der Stimm Datensätze sowie Bestandteil des Onlinewahlprodukts.
Erpressungsresistenz	Erpressungsresistenz bezeichnet die Forderung nach einer Möglichkeit die eigene Stimme des Wählenden ohne Beeinflussung durch einen Dritten abgeben zu können.
Endgerät	Das Gerät, von dem der Wählende eine Verbindung zum Onlinewahlssystem herstellt und auf dem er die Wahlhandlung tätigt.
Ende-zu-Ende-Verifizierbarkeit	Ende-zu-Ende-Verifizierbarkeit ist eine übergeordnete Anforderung, welche die Teilanforderungen Cast-as-Intended, Recorded as Cast, Counted as Recorded, Individuelle Verifizierbarkeit, Universelle Verifizierbarkeit und Verifizierbarkeit der Berechtigung sammelt.
Homomorphe Verschlüsselung	Bei einer homomorphen Verschlüsselung können mathematische Operation auf Chiffre ausgeführt werden, die der gleichen Operation auf die dazugehörigen Klartexte entsprechen. Für die Durchführung einer entsprechenden mathematischen Operation werden dabei keine Informationen über den Klartext benötigt.
Individuelle Verifizierbarkeit	Der Begriff beschreibt den Status, dass der Wählende verifizieren kann, dass seine Stimme korrekt gezählt wurde.
Mandantenfähigkeit	Die Mandantenfähigkeit beschreibt die Abgeschlossenheit eines Mandanten innerhalb eines Systems bei Soft- und Hardwaresystemen, das mehrere Mandanten verwenden. Dabei werden die Daten des Mandanten nur innerhalb dieses Mandanten verarbeitet und gespeichert und unberechtigte Dritte haben keinen Zugriff.
Mix-Nets	Konzept für die Kommunikation über verschiedene Zwischenstation, bei der die relevanten Informationen an den Zwischenstationen gemischt werden, um sie dann in zufälliger Reihenfolge an die nächste Station zu senden.
Nutzer	Ein Nutzer ist im Kontext eines Onlinewahlsystems eine Person, die sich noch nicht als Wählender authentisiert hat.
Online-Abstimmung	Online-Abstimmungen sind Abstimmungen, die in elektronischer Form eine Stimmabgabe über das Internet oder ein anderes Kommunikationsnetz ermöglichen.

Onlinestimmabgabe	Die Zustimmung des Wählenden zur endgültigen Speicherung seiner Stimme in der elektronischen Wahlurne. Die Onlinestimmabgabe ist erfolgreich, wenn die Stimme fehlerfrei in der elektronischen Wahlurne gespeichert wurde.
Onlinewahlen	Onlinewahlen sind Wahlen, die den Wahlvorgang in elektronischer Form von Stimmabgabe über die Auszählung bis zur Bekanntgabe des Wahlergebnisses über das Internet oder ein anderes Kommunikationsnetz ermöglichen.
Onlinewahlergebnis	Das Onlinewahlergebnis ist das Resultat der Stimmauszählung der Online-Stimmzettel. Die Feststellung des Wahlergebnisses umfasst die Anzahl der ungültigen Stimmen, die Anzahl der gültigen Stimmen und die summarische Verteilung der gültigen Stimmen auf die einzelnen Wahlvorschläge. Der Zeitpunkt der Stimmauszählung bestimmt die Unterscheidung von Wahlergebnis und Zwischenergebnis.
Onlinewahlprodukt	Das Onlinewahlprodukt ist eine Anwendung, die Funktionen (Einrichtung, Durchführung und Auswertung) zur Durchführung einer Onlinewahl anbietet.
Onlinewahlssystem	Das Onlinewahlssystem ist eine IT-Umgebung, die für die Durchführung einer Onlinewahl notwendig ist. Es beinhaltet die notwendigen Daten (z.B. Wahlkennzeichen, Stimmzettel), das Onlinewahlprodukt, IT-Systeme, Netze und Kommunikationsbeziehungen, sowie Räume und Gebäude.
Recorded-as-Cast	Der Begriff beschreibt den Status, dass die abgegebene Stimme korrekt erfasst und abgespeichert wurde.
Schnittstelle	Eine Schnittstelle ist eine Anbindungsmöglichkeit zur Übertragung von Daten durch oder an andere Systeme.
Stimmauszählung	Auszählung der in der elektronischen Wahlurne gespeicherten Stimmen. Dabei wird die Anzahl der gültigen sowie der ungültigen Stimmen ermittelt.
Stimmberechtigung	Das Recht zur Abgabe einer Stimme
Stimme	Inhalt eines ausgefüllten Stimmzettels, der einen Wählendenwillen, d. h. die Wahlentscheidung eines Wählenden zum Ausdruck bringt. Dies kann sowohl eine gültige als auch eine ungültige Stimme sein. Beispiele für ungültige Stimmen sind, dass der Wählende keine oder zu viele Wahlvorschläge ausgewählt hat.
Stimmzettel	Der Stimmzettel ist eine Abbildung der Liste der Wahlvorschläge und weiterer Informationen, die zur Abgabe einer Stimme ausgefüllt werden müssen.
Universelle Verifizierbarkeit	Jeder kann überprüfen, dass das Wahlergebnis korrekt zustande gekommen ist.
Verifizierbarkeit der Berechtigung	Dies bedeutet, dass es Beobachtern möglich sein muss zu verifizieren, dass alle Stimmen von berechtigten Wählenden abgegeben wurden. Dies beinhaltet unter anderem auch, ausschließen zu können, dass Stimmen durch den Organisator der Wahl hinzugefügt wurden.
Wahlberechtigte	Wahlberechtigte sind Personen, die nach dem geltenden Recht und unter Betrachtung des Grundsatzes der Allgemeinheit an einer Wahl teilnehmen dürfen.
Wahlende	Das Wahlende bezeichnet den Zeitpunkt, zu dem der Wahlvorstand die Wahldurchführung am Onlinewahlssystem beendet.

Wählender	Person, die am Endgerät Funktionalitäten des Onlinewahlsystems mit dem Ziel benutzt, eine Wahlhandlung oder Teile davon auszuführen und eine Berechtigung zur Ausführung dieser Wahlhandlung besitzt.
Wählendenverzeichnis	Verzeichnis aller Personen, die zur Teilnahme an der Onlinewahl berechtigt sind.
Wahlgang	Die Durchführung des Prozesses einer Stimmabgabe
Wahlgeheimnis	Dies bezeichnet die Eigenschaft, dass die Wahlentscheidung des Wählenden nicht beobachtet sowie durch Andere nicht rekonstruiert werden kann.
Wahlhandlung	Eine Wahlhandlung umfasst alle Schritte die ein Wählender bei einer Wahlhandlung im Rahmen einer Onlinewahl durchläuft: - Identifizierung und Authentifizierung mit Stimmberechtigungsprüfung, - Ausfüllen des Stimmzettels, - Korrektur und Einleitung der Stimmabgabe, - Anzeige der Stimme, Widerruf oder endgültige Abgabe der Stimme, - Rückmeldung an den Wählenden
Wahlkalender	Liste von Terminen, die im Kontext der Wahl relevant sind, wie z.B. die Fristen (Wahlende, etc.)
Wahlkandidat	Person, die im Rahmen einer Wahl gewählt werden kann.
Wahlkennzeichen	Eindeutiges Kennzeichen zur Unterscheidung von Stimmberechtigungen.
Wahlkennzeichen-Liste	Liste aller Wahlkennzeichen die zur Onlinewahl stimmberechtigt sind.
Wahniederschrift	Protokoll der Ergebnisse der Wahl
Wahlphase	Bezeichnet eine Phase im Rahmen einer Wahl, wie beispielsweise Vorbereitung, Durchführung, Auswertung und Nachbereitung.
Wahlgrundsätze	Wahlgrundsätze formulieren grundlegende Anforderungen an demokratische Wahlen. Es werden die folgenden Wahlgrundsätze unterschieden: Allgemein, Unmittelbar, Frei, Gleich, Geheim und den Grundsatz der Öffentlichkeit der Wahl.
Wahlgrundsatz: Allgemein	Der Wahlgrundsatz der Allgemeinheit fordert, dass ein Zugang zur Wahl unabhängig von Merkmalen wie Geschlecht (unabhängig von verschiedenen Wahlen, bspw. der Wahl zur Gleichstellungsbeauftragten), Rasse, Vermögen oder Religionszugehörigkeit stets gewährleistet sein muss. Unabhängig davon kann es Einschränkungen geben, beispielsweise bei einer Vereinswahl, bei der nur Mitglieder wählen dürfen.
Wahlgrundsatz: Frei	Der Wahlgrundsatz der Freiheit fordert, dass die Wählenden ihr Wahlrecht ohne Zwang oder sonstige unzulässige Beeinflussung von außen, ausüben können.
Wahlgrundsatz: Geheim	Dieser Wahlgrundsatz besagt, dass der Wahlvorgang so stattfinden muss, dass die eigene Wahlhandlung nur für den Wählenden selbst nachvollziehbar ist. Gilt der Wahlgrundsatz geheim nicht, dann können auch öffentliche Wahlen durchgeführt werden.
Wahlgrundsatz: Gleich	Nach dem Wahlgrundsatz der Gleichheit muss jeder Wahlberechtigte die gleiche Stimmenanzahl besitzen und jede abgegebene Stimme muss das gleiche Gewicht bei der Zusammensetzung des Wahlergebnisses haben. Ausnahmen hierzu sind bspw. Wahlen im Rahmen von Hauptversammlungen etc.

Wahlgrundsatz: Öffentlichkeit	Dieser Wahlgrundsatz besagt, dass wesentliche Teile der Wahl, wie insbesondere die korrekte Auszählung, durch die Öffentlichkeit überprüfbar sein müssen.
Wahlgrundsatz: Unmittelbar	Dieser Wahlgrundsatz bedeutet, dass die zu Wählenden durch die Wählenden mittels Direktwahl gewählt werden und insbesondere nicht durch Mittelsmänner wie Wahlmänner.
Wahlveranstalter	Organisation, die eine Wahl durchführen lässt. Im Sinne der Neutralität sollte eine Wahl nicht vom Wahlveranstalter organisiert werden. Die Organisation der Wahl obliegt dem Wahlvorstand.
Wahlvorbereitung	Durchführung diverser Aktivitäten zur Vorbereitung einer Wahl. Darunter kann z.B. die Festlegung des Wahlzeitraums, die Erstellung eines Stimmzettels oder die Zusammenstellung der Wahlvorschlagsliste fallen.
Wahlvorstand	Eine Gruppe von Personen, die die organisatorische Verantwortung für die Onlinewahl haben und diese leiten. Dies beinhaltet auch alle „Erfüllungsgehilfen“ (z. B. Mitarbeiter eines mit der Abwicklung beauftragten Wahldienstleisters), die im Auftrag und unter Kontrolle leitender Personen des Wahlvorstandes: - die Administration des Onlinewahlsystems durchführen, - die Wahldurchführung starten, - einen Wiederanlauf veranlassen, - die Wahldurchführung beenden, - sowie die Stimmauszählung mit Feststellung des Wahlergebnisses starten.
Wahlzeitraum	Gesamter Zeitraum in dem während einer Wahl die Abgabe der Stimme möglich ist.

Tabelle 3: Glossar

8 Literaturverzeichnis

1. **Bundesverfassungsgericht.** Verwendung von Wahlcomputern bei der Bundestagswahl 2005 verfassungswidrig. [Online] 3. März 2009.
<https://www.bundesverfassungsgericht.de/SharedDocs/Pressemitteilungen/DE/2009/bvg09-019.html>.
2. **Bundesamt für Sicherheit in der Informationstechnik.** Common Criteria Protection Profile – for E-Voting Systems for non-political Elections, Version 1.0. [Online] [Zitat vom: 23. 01 2025.]
https://www.bsi.bund.de/SharedDocs/Zertifikate_CC/PP/aktuell/PP_0121.html.
3. **Bundesministerin der Justiz und für Verbraucherschutz.** Verordnung über die Wahl der Gleichstellungsbeauftragten und ihrer Stellvertreterinnen in Dienststellen des Bundes (Gleichstellungsbeauftragtenwahlverordnung - GleibWV). *Verordnung über die Wahl der Gleichstellungsbeauftragten und ihrer Stellvertreterinnen in Dienststellen des Bundes (Gleichstellungsbeauftragtenwahlverordnung - GleibWV)*. [Online] 17. 12 2015. https://www.gesetze-im-internet.de/gleibwv_2015/BJNR227410015.html.
4. **Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit.** Datenschutz-Grundverordnung - Bundesdatenschutzgesetz - Texte und Erläuterungen. *Datenschutz-Grundverordnung - Bundesdatenschutzgesetz - Texte und Erläuterungen*. [Online] [Zitat vom: 18. 08 2025.]
<https://www.bfdi.bund.de/SharedDocs/Downloads/DE/Broschueren/INFO1.html>.
5. **Bundesamt für Sicherheit in der Informationstechnik.** IT-Grundschutz-Kompendium. [Online] 2023. [Zitat vom: 19. 08 2025.] https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/it-grundschutz-kompendium_node.html.
6. **Bundesministerium für Justiz und Verbraucherschutz.** Grundgesetz. [Online] [Zitat vom: 19. 08 2025.]
https://www.gesetze-im-internet.de/gg/art_38.html.
7. **Bundesministerin der Justiz und für Verbraucherschutz.** Gesetz für die Gleichstellung von Frauen und Männern in der Bundesverwaltung und in den Gerichten des Bundes. *Gesetz für die Gleichstellung von Frauen und Männern in der Bundesverwaltung und in den Gerichten des Bundes*. [Online] 24. 04 2015.
https://www.gesetze-im-internet.de/bgleig_2015/BJNR064300015.html.
8. —. Verordnung über die Wahl der Gleichstellungsbeauftragten und ihrer Stellvertreterinnen in Dienststellen des Bundes. *Verordnung über die Wahl der Gleichstellungsbeauftragten und ihrer Stellvertreterinnen in Dienststellen des Bundes*. [Online] 17. 12 2015. https://www.gesetze-im-internet.de/gleibwv_2015/BJNR227410015.html.
9. **Bundesamt für Sicherheit in der Informationstechnik.** BSI TR-02102-2 "Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS)". *BSI TR-02102-2 "Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS)"*. [Online] 19. 02 2024.
<https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102-2.html>.
10. —. TR-03107-1 Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1. *TR-03107-1 Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1*. [Online] 07. 05 2019.
<https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.html>.
11. **Bundesamt für Sicherheit in der Informationstechnik.** BSI-Standard 200-2. *BSI-Standard 200-2*. [Online] [Zitat vom: 18. 08 2025.] https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-2-IT-Grundschutz-Methodik/bsi-standard-200-2-it-grundschutz-methodik_node.html.

12. **Bundesamt für Sicherheit in der Informationstechnik.** Informationssicherheit und IT-Grundschutz. BSI-Standards 200-1, 200-2, 200-3. [Online] 2020. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/bsi-standards_node.html.
13. —. Handlungsleitfaden für Wählende. [Online] [Zitat vom: 15. 01 2025.] https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Broschueren/Handlungsleitfaden_nicht-politische_Onlinewahlen.pdf?__blob=publicationFile&v=5.
14. —. BSI TR-03107 Elektronische Identitäten und Vertrauensdienste im E-Government. [Online] 7. Mai 2019. https://www.bsi.bund.de/DE/Publikationen/TechnischeRichtlinien/tr03107/index_hm.html. Version 1.1.1.
15. **Bundesministerin der Justiz und für Verbraucherschutz.** Gesetz über Personalausweise und den elektronischen Identitätsnachweis (Personalausweisgesetz - PAuswG). *Gesetz über Personalausweise und den elektronischen Identitätsnachweis (Personalausweisgesetz - PAuswG)*. [Online] 18. 06 2009. <https://www.gesetze-im-internet.de/pauswg/BJNR134610009.html>.
16. **Bundesministerium für Justiz und für Verbraucherschutz.** Gesetz über den Aufenthalt, die Erwerbstätigkeit und die Integration von Ausländern im Bundesgebiet. *Gesetz über den Aufenthalt, die Erwerbstätigkeit und die Integration von Ausländern im Bundesgebiet*. [Online] [Zitat vom: 19. 08 2025.] https://www.gesetze-im-internet.de/aufenthg_2004/.
17. **Bundesministerium für Justiz und Verbraucherschutz.** Gesetz über eine Karte für Unionsbürger und Angehörige des Europäischen Wirtschaftsraums mit Funktion zum elektronischen Identitätsnachweis. [Online] 21. 06 2019. <https://www.gesetze-im-internet.de/eidkg/BJNR084610019.html>.
18. **Bundesamt für Sicherheit in der Informationstechnik.** BSI TR-02102-1 Kryptographische Verfahren: Empfehlungen und Schlüssellängen. [Online] <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.html>.
19. —. Leitfaden IS-Revision. *Leitfaden IS-Revision*. [Online] 2018. [Zitat vom: 22. 06 2021.] https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Sicherheitspruefungen/ISRevision/Leitfaden/leitfaden_node.html.
20. —. BSI-Studie "Durchführungskonzept für Penetrationstests". [Online] 2020. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Studien/Penetrationstest/penetrationstest.pdf?__blob=publicationFile&v=3.
21. **BSI Handlungsleitfaden für Wahlorganisatoren zu Ende-zu-Ende verifizierbaren Onlinewahlen.** Onlinewahlen für Wahlverantwortliche und Wählende. [Online] [Zitat vom: 15. 01 2025.] https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Online-Wahlen/Online-Wahlen_Wahlverantwortliche/online-wahlen_wahlverantwortliche_node.html.
22. **Bundesamt für Sicherheit in der Informationstechnik.** BSI-Standard-200-4-Business Continuity Management. [Online] 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/bsi-standard-200-4_Business_Continuity_Management_node.html.
23. **BSI ISO 27001 Zertifizierung auf Basis von IT-Grundschutz.** ISO 27001 Zertifizierung auf Basis von IT-Grundschutz. *ISO 27001 Zertifizierung auf Basis von IT-Grundschutz*. [Online] https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Zertifizierung-und-Anerkennung/Zertifizierung-von-Managementsystemen/ISO-27001-Basis-IT-Grundschutz/iso-27001-basis-it-grundschutz_node.html.
24. **EU Verordnung.** EU eIDAS Verordnung 910/2014. *EU eIDAS Verordnung 910/2014*. [Online] 23. Juli 2014. <https://eur-lex.europa.eu/legal-content/DE/TXT/PDF/?uri=CELEX:32014R0910&from=EN>.

25. **Bundesamt für Sicherheit in der Informationstechnik.** Leitlinie für digitale Signatur-/ Siegel-, Zeitstempelformate sowie technische Beweisdaten (Evidence Record). [Online] 26. März 2020. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03125/BSI_TR_03125_Leitlinie_fuer_digitale_Signatur-Siegel-Zeitstempelformate.pdf?__blob=publicationFile&v=3. Version 1.0.
26. —. BSI TR-03116-4 Kryptographische Vorgaben für Projekte der Bundesregierung Teil 4: Kommunikationsverfahren in Anwendungen. [Online] 07. 03 2023. <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03116/BSI-TR-03116-4.html>.
27. —. BSI Key Lifecycle Security Requirements. [Online] 2. November 2018. <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/ElekAusweise/CVCA/KeyLifecycleSecurityRequirements.pdf>. Version 1.0.2.
28. —. Mindeststandard des BSI zur Protokollierung und Detektion von Cyber-Angriffen. [Online] 2023. [Zitat vom: 15. 01 2025.] <https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Mindeststandards/PDCA/PDCA.html>. Version 1.0.
29. **Bundesministerium für Justiz und Verbraucherschutz.** Vertrauensdienstegesetz. [Online] 18. Juli 2017. <https://www.gesetze-im-internet.de/vdg/BJNR274510017.html>.
30. **Bundesamt für Sicherheit in der Informationstechnik.** TR-03125 Beweiswerterhaltung kryptographisch signierter Dokumente. [Online] 15. März 2018. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03125/TR-03125_node.html.
31. —. Zertifizierung nach ISO 27001 auf der Basis von IT-Grundschutz - Zertifizierungsschema. *Zertifizierung nach ISO 27001 auf der Basis von IT-Grundschutz - Zertifizierungsschema*. [Online] 21. 05 2019. [Zitat vom: 22. 06 2021.] https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/Zertifikat/ISO27001/Zertifizierungsschema_Kompendium.pdf.
32. —. Business Impact Analyse. *Business Impact Analyse*. [Online] https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/Zertifizierte-Informationssicherheit/IT-Grundschutzschulung/Online-Kurs-Notfallmanagement/3_BusinessImpactAnalysieren/BIA_node.html.
33. **Bundesministerium der Justiz.** Verordnung über die technischen und organisatorischen Vorgaben für die Durchführung einer Online-Wahl im Rahmen des Modellprojekts nach § 194a des Fünften Buches Sozialgesetzbuch. *Verordnung über die technischen und organisatorischen Vorgaben für die Durchführung einer Online-Wahl im Rahmen des Modellprojekts nach § 194a des Fünften Buches Sozialgesetzbuch*. [Online] 23. 09 2020. <https://www.gesetze-im-internet.de/onlwahlv/>.
34. **Bundesamt für Sicherheit in der Informationstechnik.** Technische Richtlinie TR-03169. [Online] 19. 09 2023. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03169/BSI-TR-03169.pdf?__blob=publicationFile&v=7.
35. —. BSI TR-03162 IT-sicherheitstechnische Anforderungen zur Durchführung einer Online-Wahl im Rahmen des Modellprojekts nach § 194a Fünftes Buch Sozialgesetzbuch (Online-Wahl). [Online] 03. 02 2023. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03162/BSI-TR-03162.pdf?__blob=publicationFile&v=15.
36. **BSI Mindeststandard Web.** Mindeststandard des BSI für sichere Web-Browser. [Online] 25. Juni 2020. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Mindeststandards/Mindeststandard_Sichere_Web-Browser_V2_0.pdf?__blob=publicationFile&v=3. Version 2.1.

37. **EinhZeitG.** Gesetz über die Einheiten im Messwesen und die Zeitbestimmung (Einheiten- und Zeitgesetz - EinhZeitG). [Online] https://www.gesetze-im-internet.de/me_einhg/EinhZeitG.pdf.
38. **BSI Benutzerdefinierte Bausteine.** Benutzerdefinierte Bausteine. *Benutzerdefinierte Bausteine*. [Online] 16. 06 21. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/Hilfsmittel-und-Anwenderbeitraege/Benutzerdefinierte-Bausteine/benutzerdefinierte-bausteine_node.html.
39. **Bundesamt für Sicherheit in der Informationstechnik.** BSI. *BSI*. [Online] 20. 02 2024. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Zertifizierung/Reporte/ReportePP/pp0121b_pdf.pdf?__blob=publicationFile&v=4.
40. **Bundesministerium für Justiz und Verbraucherschutz.** Gesetz über Personalausweise und den elektronischen Identitätsnachweis. *Gesetz über Personalausweise und den elektronischen Identitätsnachweis*. [Online] 18. 06 2009. <https://www.gesetze-im-internet.de/pauswg/BJNR134610009.html>.